

Authentication Protocols and Technologies

Dr. Mohammed Misbahuddin

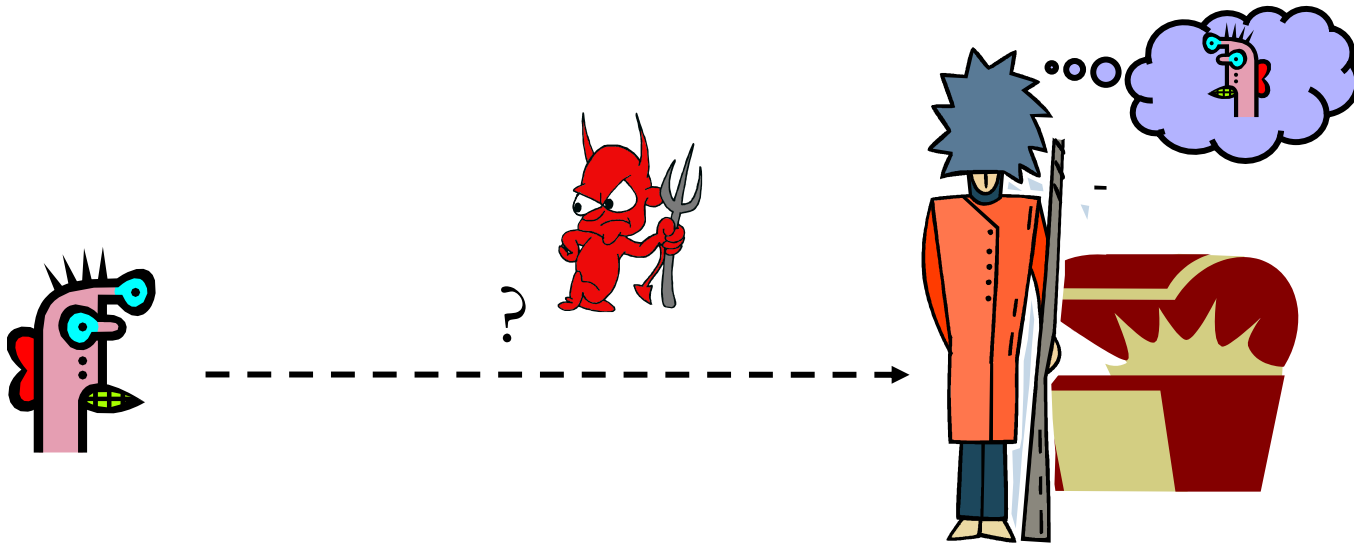
Centre for Development of Advanced Computing,
Bangalore - India

Agenda



- Introduction
- Issues with current systems
- Key Challenges
- Our Proposed Solution
- e-Pramaan

Basic Problem



How do you prove to someone that
you are who you claim to be?

- In the earlier days a person's reputation was developed over time as he or she becomes known in the community ... a handshake was good enough to finalize a deal.....
- however, as a community becomes larger, and distance greater, it becomes necessary to provide formal documents that “vouchsafe” identity and character.

The “usual” documents include

- Birth certificate
- Driver’s license (or alternative)
- Passport

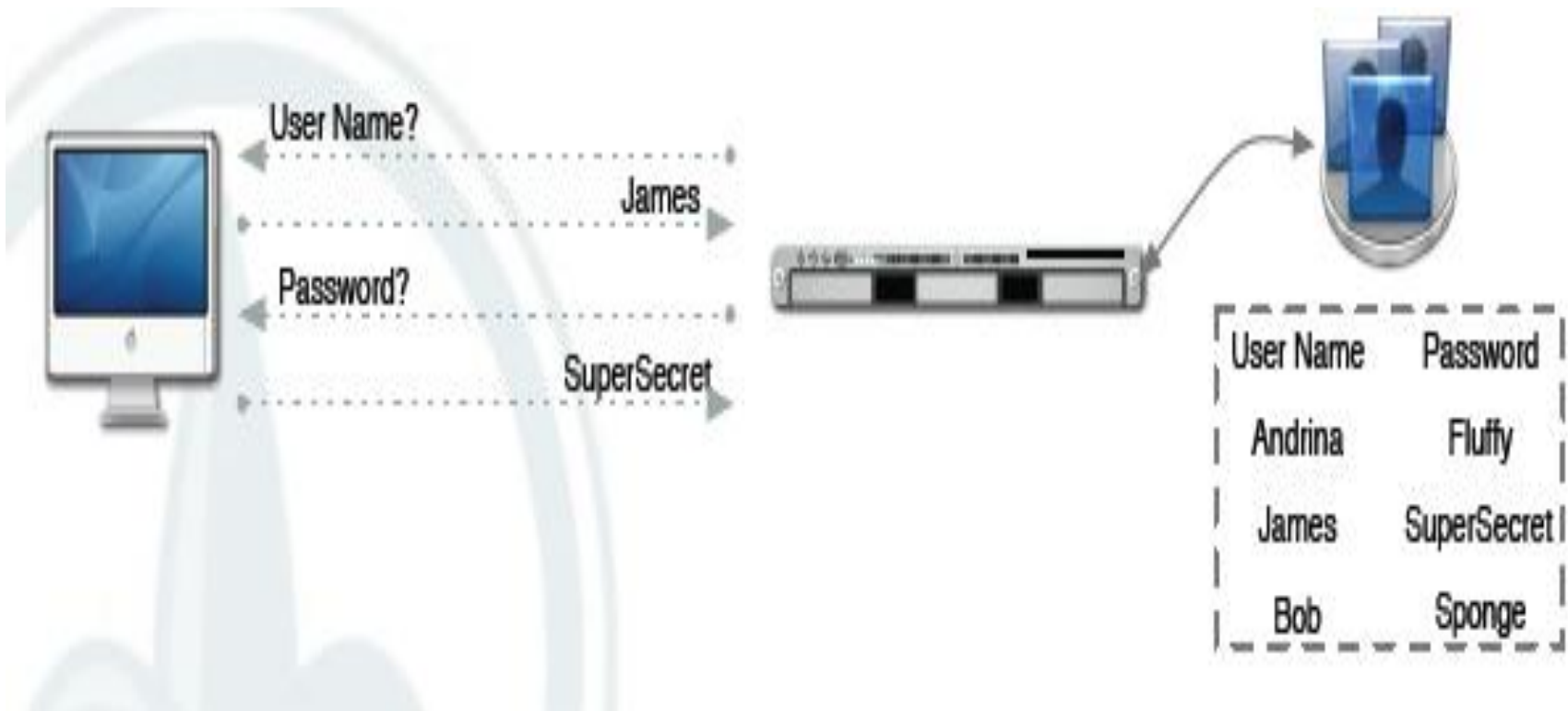
Along with others – college id, credit card, even utility bills!

The Internet “community” is too large for people to know everyone else directly, and on-line “identities” such as I am a good guy can be changed readily;

The face-to-face methods aren’t available here to ascertain who someone is, how reliable he is, what level of privilege is available to him, and what is his identity

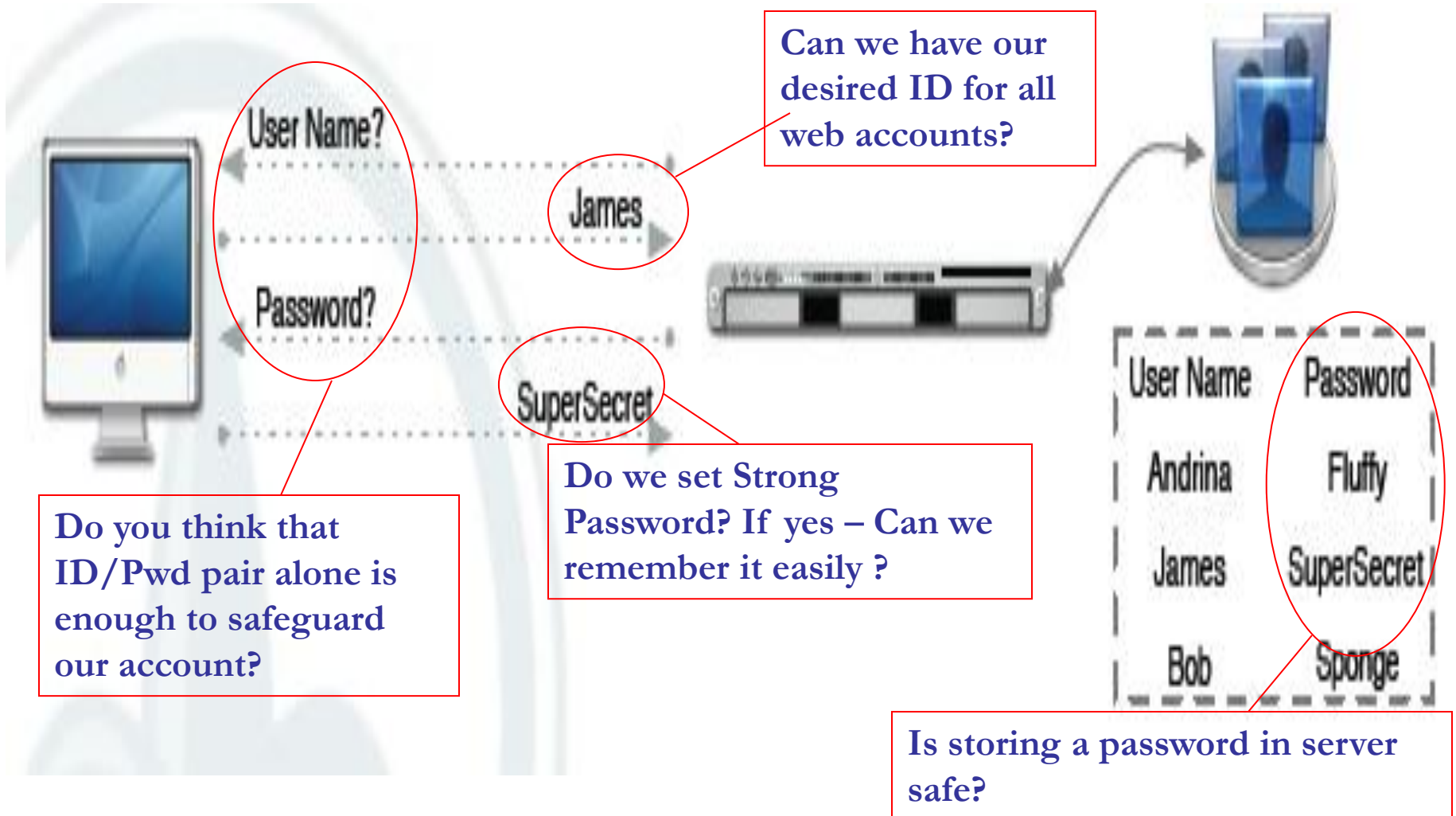
- The primary means to ascertain identity on computing systems is by means of a user ID and associated password or Personal Identification Number (PIN).
- This is the most simple & common way to prove that you are the legitimate user.

Basic Authentication

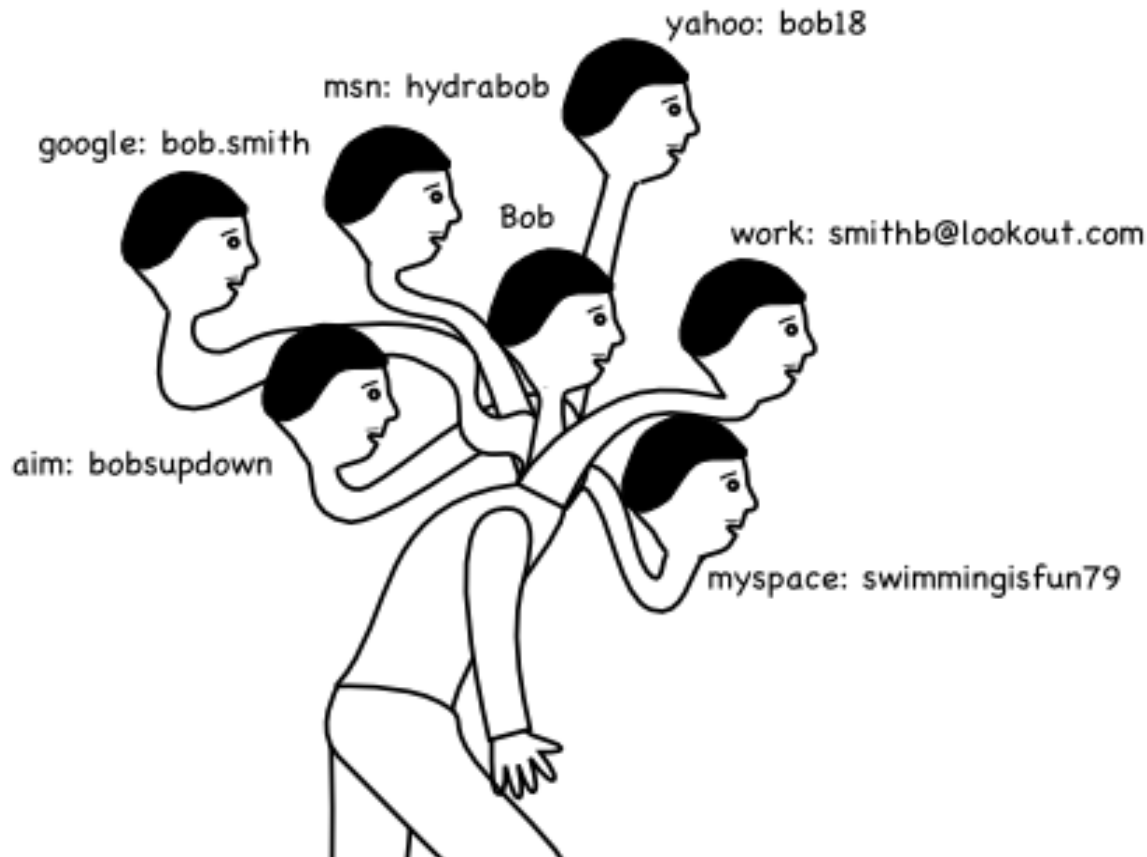


Issues with Current Systems

Issues in Basic Authentication



User IDs - Availability Issues



Each user has 25 personal and work accounts which require passwords

Requirements for Password



Easy to remember



- Look random
- Hard to guess

To set a Password

- A password should have a minimum of 8 characters, be as meaningless as possible, should have uppercase letters, lowercase letters and numbers

Eg. xk28LP97

- Change passwords regularly.
- Do not give out your password to anyone!

To Remember Password

- I feel great = If33lg8!
- Wildcats are #1 = W1ldcatzR#1
- Dolphins Fan = d0lf1n'sfan

Passwords – Memorability Issues

How many passwords we maintain ?

Each user types about 8 passwords a day

People just cant remember their passwords

82% of users have forgotten passwords



Requirements for Password



Easy to remember



- Look random
- Hard to guess

To set a Password

- A password should have a minimum of 8 characters, be as meaningless as possible, should have uppercase letters, lowercase letters and numbers

Eg. xk28LP97

- Change passwords regularly.
- Do not give out your password to anyone!

To Remember Password

- I feel great = If33lg8!
- Wildcats are #1 = W1ldcatzR#1
- Dolphins Fan = d0lf1n'sfan

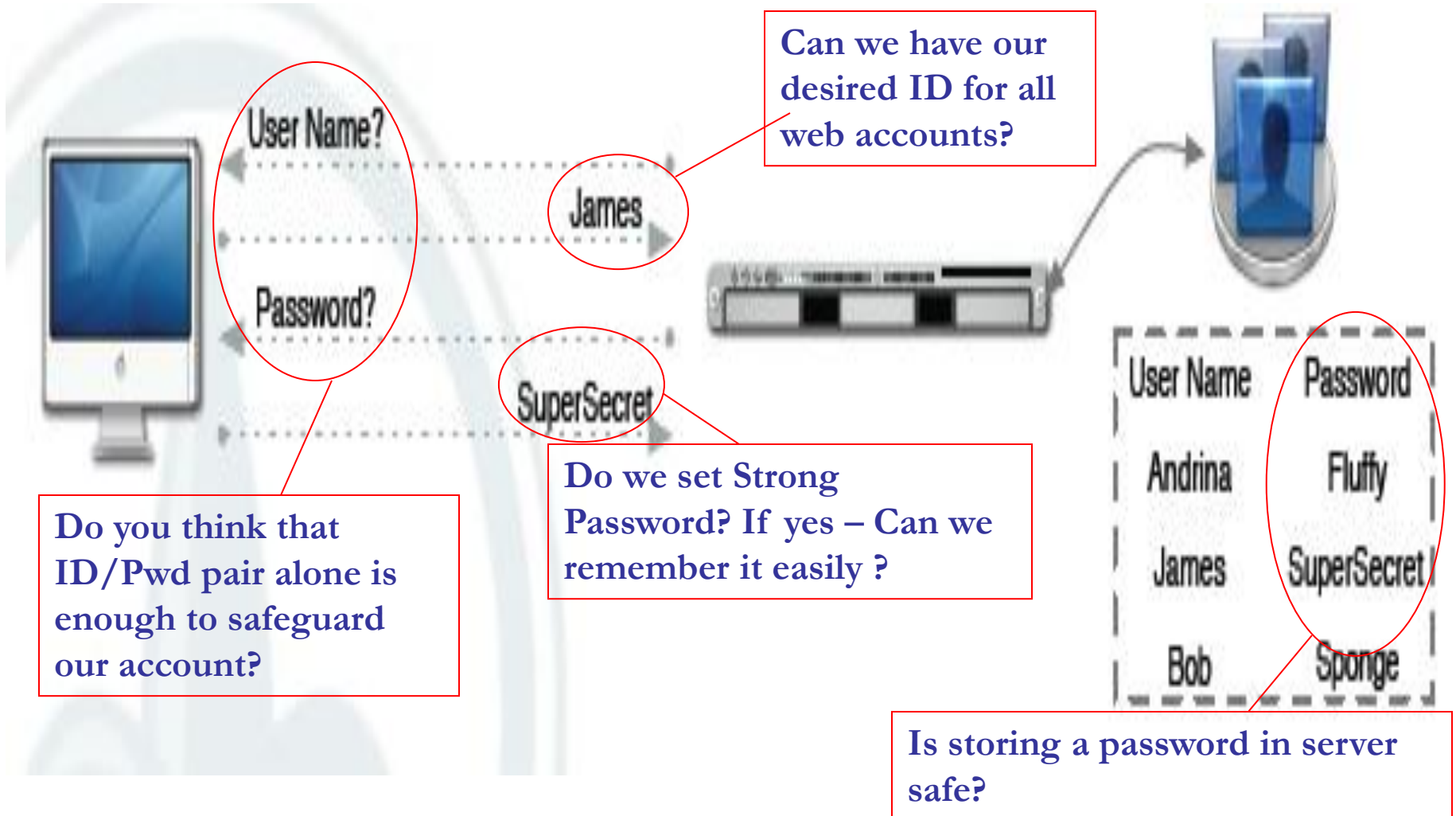
- Company security is weakened by employees who can't remember passwords
 - 65% of users use same password for different applications
 - 74% knew their co-workers password which means weakened security and more exposure

Impact on Business



- If customer don't trust your security, they will not use your website
 - 80% of adults said that they would buy more from an online store whose security is just **more than simple username and password**
 - 47% of adults surveyed, don't bank online because they **fear their account information will be viewed by unauthorized party**
- FFIEC guidelines for online financial organizations

Issues in Basic Authentication



Key Challenges



1. Addressing Identity Problems
2. Providing Strong Authentication
3. Authenticating without Password Table
4. Providing Usable and Strong Passwords

Key Challenge – 1 :

Addressing Identity Problems

OpenID

- Addressing Identity problems
 - Open ID



OpenID is a free and easy way to use a **single digital identity** across the Internet.

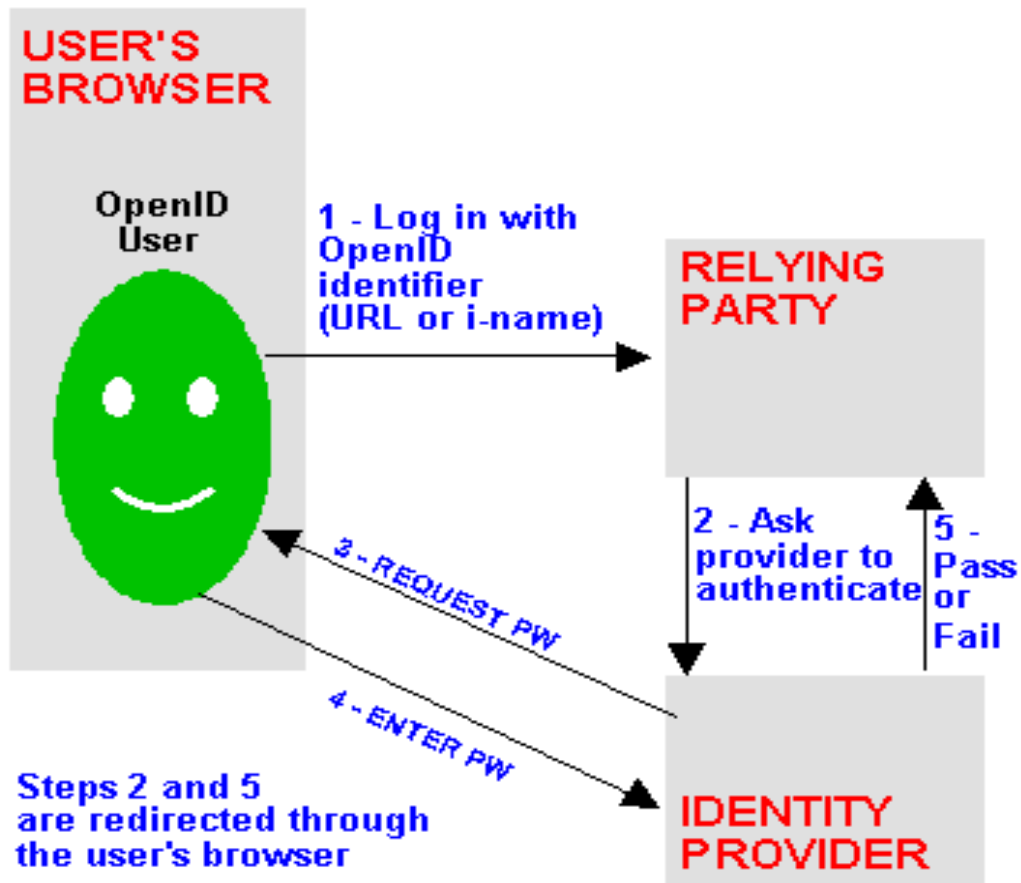


With one OpenID you can login to all your **favorite websites** and forget about online paperwork!

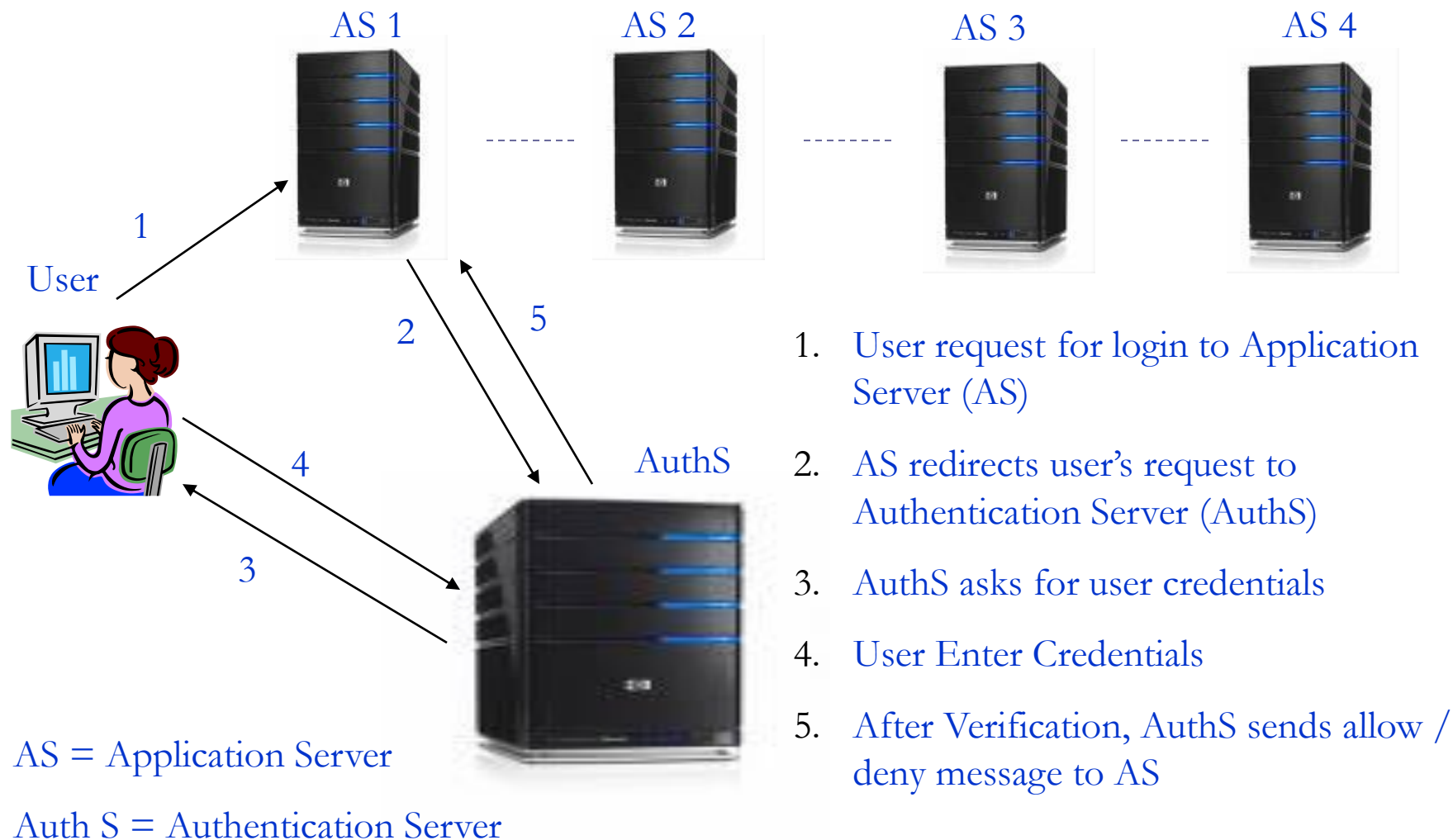


OpenID Explained

From Computer Desktop Encyclopedia
© 2008 The Computer Language Co., Inc.



Authentication As a Service (AAS)



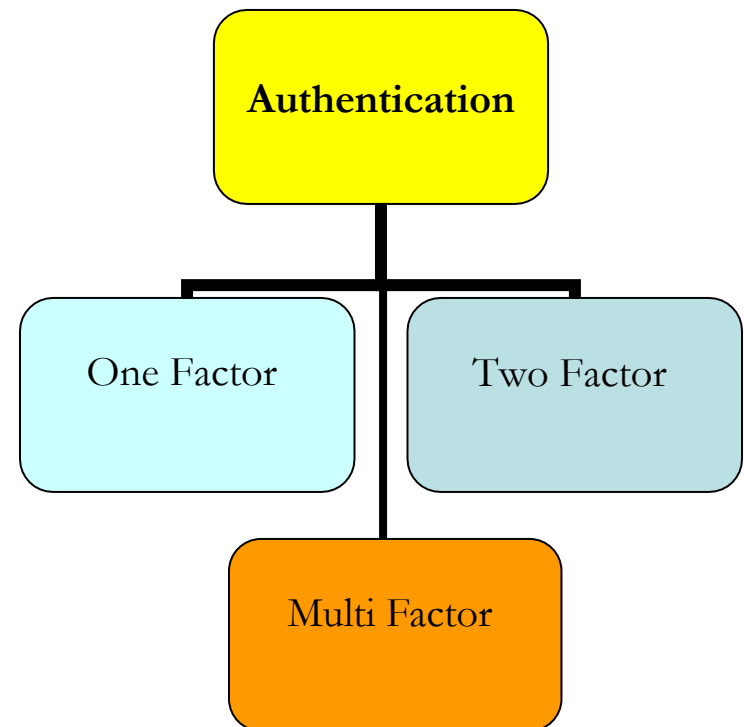
Key Challenge – 2 :

Providing Strong Authentication

What is Factor ?

- A factor is a secret which a user knows/holds/possess
- Typically a user is authenticated based on **one** or **two** or **all** of the following factors
 - **Something You Know**
(Eg: Password, PIN etc.)
 - **Something You Have**
(Eg: Smart card, Token etc.)
 - **Something You Are**
(Eg: Biometrics, Keystroke Dynamics etc.)

Based on these factors, Authentication mechanisms can be categorized as



Strong Authentication



- Single Factor – The traditional ways of Authentication where user enters a user ID & Password
- Two Factor – A Combination of User ID/Password plus a secret value from Soft token /USB Token/Smart Card which the user holds
- Multi Factor – A Combination on Two or More different Factors

Examples of Single Factor Authentication

Example Login pages from INGDirect



ING DIRECT
save your money®

Français Tools FAQ Contact Us Search

I'm a Client, let me in! Save & Invest Mortgages About Us Accounts & Rates Sign me up!

Enter Your PIN

BACK NEXT

Security Update

We have introduced a new secure login. You will be asked for your PIN after keying in your Client Number. After you complete logging in, you will see new security setup screens.

Careers Site Map ING DIRECT Worldwide Privacy Legal Security

start 3 Firefox PKI Program Co... PKI Workshop 2 Microsoft Of... Authentication i... Microsoft Office... 2:14 PM

Contd...



Browser address bar: <https://secure.ingdirect.com/myaccount/INGDirect.html?command=displayCustomerAuthenticate&f>

Browser tabs: expedite - Definitions from Dictionary..., (0 unread) Yahoo! Mail, mdmisbahuddin, Gmail - Technical Review of Core Proje..., ING DIRECT

ING DIRECT Save Your Money®

View my Account

Open an Account

Products & Rates

Tips & Tools

About Us

FAQ

Welcome Keith You entered Saver ID srinivas.

[If this is not your information please click here.](#)

2 Answer Your Security Questions

The computer you are using is not registered with us, so please answer the two questions below.

What is your mother's middle name?

In what city was your mother born? (enter full name of city only)

☐ Hide my typing

[Don't know these answers?](#)

Save time!

☐ Register this computer to skip these security questions next time you login from this computer.

We recommend that you only register computers that are private, such as your home computer.

Next

SECURED BY **RSA**

MEMBER FDIC

EQUAL HOUSING LENDER

[Contact](#) | [Legal](#) | [Security Guarantee & Privacy](#) | [Join Our Team](#) | [Cafés](#) | [The Shop](#) | [Kids](#)

Example Login Pages from HSBC



Browser address bar: https://www.hsbc.co.uk/1/2/;jsessionid=0000IatCwNPerrjZ1EoyrbW8G1Y:12c58n73a?idv_cmd=id

Browser tabs: ING DIRECT - Login, My Security for Internet Banking...

HSBC United Kingdom You are viewing Personal Banking

HSBC  **The world's local bank** Personal | Business | Corporate

Personal Home | Current accounts | Savings | Investments | Credit Cards | Loans | Mortgages | Insurance | International Services | HSBC Premier | Green

My security for Internet Banking

You are logging on as **IB5858659741**. If this is not your Internet Banking user ID [click here](#).

Please enter:

Your **date of birth** (ddmmyy)

The **SECOND** and **NEXT TO LAST** and **LAST** digits of your Security Number 

[Forgotten your Security Number?](#)

[Back](#) [Continue](#)

Internet Banking
Personal
[Register](#) [Security](#) [Information](#)

Legal information | Accessibility | About HSBC | Careers | Site Map | Branch Locator | Contact us Issued for UK use only | © HSBC Bank plc 2002 - 2008

Example Login of Bank of America



Online Banking

Here's How SiteKey Works

By passing back and forth secret information that only you and Bank of America know, you can feel even more secure with your Online Banking experience. We recognize you and you recognize us.



Enter your Online ID.



Click **Sign In using my SiteKey**.

Your SiteKey Image
and Message:



cute dog



If we recognize your computer:

We will show you your secret SiteKey. If you are vision-impaired, you can recognize your SiteKey by its specific name and message.

What was your high school mascot?

* Answer:



If we don't recognize your computer:

We will ask you one of your secret SiteKey Confirmation Questions.

After you answer your question correctly, we will show you your SiteKey.

Passcode:



Once you view your valid SiteKey, you can then safely enter your Passcode and continue onto your Online Banking account.

Example Login Pages of SBIOnline



[About OnlineSBI](#) | [Registration Forms](#) | [Net Banking Branches](#)



Welcome : Mr. MOHAMMED MISBAHUDDIN

[Products & Services](#) [How Do I?](#) [Customer Care](#) [Help](#)

[Logout](#)

[My Accounts](#) [Payments/Transfers](#) [Bill Payments](#) [Requests](#) [Enquiries](#) **[Profile](#)** [E-Tax](#) [DEMAT/IPO](#)

You are here: [Profile](#) > [Verify Password](#)

Favourites

Jump to:

Your previous site visit:
12-Apr-2009 10:27 IST

Last Internet Banking
Transaction:
Merchant Payments
13-Apr-2009 11:14 IST

Add Biller

17-Apr-2009 [03:08 PM IST]

Mandatory fields are marked with an asterisk (*)

Profile Password *

[Forgot Profile Password](#)

Example Login Pages of IRCTC



**Indian Railway Catering and Tourism Corporation Limited**
A Government of India Enterprise

हिन्दी वेबसाइट (Beta) [Contact Us](#)

[Train Reservation](#) | [Loyalty Program](#) | [Tourist Trains](#) | [Tour Packages](#) | [Book Cabs](#) | [Hotels](#)

Login
Username:
Password:

[Signup](#) [Forgot Password](#) [Agent Login](#) [Find Agents](#)
☒ Train Ticket
☐ Tourism Services
☐ Mumbai Season Ticket

IRCTC Updates / Alerts
Revision of Fares with effect from 01-04-2009
[Click here to find IRCTC](#)


24x7 Customer Care
011 - 2334 0000
Mon - Sat (10 AM to 6 PM)
011 - 2334 5500
011 - 2334 4787/4773/5800
011 - 2334 8539/8543
Chennai Customer Care
044 - 2530 0000
Email: care@irctc.co.in

**MAHAPARINIRVAN EXPRESS**
Trace the footsteps of Buddha
Travel with Mahaparinirvan Express
Buddhist Circuit Special Train



[Help & Info](#) | [Enquiries](#) | [Loyalty Program](#) | [Special Offers](#) | [IRCTC Zone](#) | [Mobile Zone](#) | [Catering](#)

User Guides
I-Ticket
E-Ticket
Season Ticket
Soft User Guide
Quick Ticket Guide
Browser Setting

General
Rules & Policies
Frequently Asked Questions
Statistics
Terms And Conditions
50% Tatkal Quota
New Facilities In E-Ticket
Women Sr.Citizens Concession
Scheme for issue of waitlisted E-tickets

Ticket Delivery
Areas Covered
Pincodes Covered
Cancellation Procedure
I-Tickets
E-Tickets
Security
Protect against fraudulent emails

Information for Agents
RTSA
IATA / TAAI / TAFI
INTERNET CAFE SCHEME
IRCTC Authorised Agents
Do's & Dont's For The Agents
Booking/Cancellation Request Slip for Agents

Example Login Pages of IRCTC



Indian Railway Catering and Tourism Corporation Limited

A Government of India Enterprise

17-Apr-2009 [15:18:41 GMT+05:30] [Contact Us](#) [Log Out](#)

[Train Reservation](#)

[Loyalty Program](#)

[Tourist Trains](#)

[Tour Packages](#)

[Book Cabs](#)

[Hotels](#)

User Profile

- [Update Profile](#)
- [Change Password](#)
- [Master List of Passengers](#)
- [Passenger Travel List](#)

My Transactions

- [Print E-Ticket](#)
- [Cancel E-Ticket](#)
- [File TDR](#)
- [Booked History](#)
- [Cancelled History](#)
- [TDR History](#)
- [Offline Cancellation](#)
- [Banner Auction](#)
- [Refund Status](#)

Services

- [Plan My Travel](#)

Re-enter Password

*Mandatory

Enter Your Password *

••••••••

[GO](#)

[Reset](#)

Examples of Two Factor Authentication using Digital Certificates

Examples of Something you have



Crypto Token containing DSC



Smart Card containing DSC



OTP Smart Cards



OTP Tokens

Digital Signature – Security Factors



- **Vulnerability to attacks**
 - Digital Signature is a Secure Technology
- **Multiple factors of authentication**
 - Very Strong if used in combination with a password
- **Protection from phishing attacks**
 - Yes
- **Effect of use on untrusted local machine**
 - No Effect if used with Hardware Crypto Token
- **Usability as a security issue**
 - User need to remember a short PIN rather than a long password

Examples of Two Factor Authentication using Biometrics

Overview of Biometric based Authentication

- Biometrics refers to the automatic identification or verification of individuals by using their physical or behavioural characteristics.
- A biometric system is essentially a pattern recognition system which recognizes a user by determining the authenticity of a specific Physiological or Behavioural characteristic possessed by the user.

- There are two different ways to recognize a person:
 - Identification (*Who am I?*) the system has to recognize a person from a list of N users in the template database.
 - Verification (*Am I who I claim to be?*) – It involves confirming or denying a person's *claimed identity*. The user has to be enrolled already.
 - Identification is a more challenging problem because it involves $1:N$ matching compared to $1:1$ matching for verification.

Types of Biometrics



- Two main types:
 - **Physiological Biometrics:** Uses a physical trait, such as a fingerprint, iris, hand or face for recognition. The physical trait is analysed, measured and digitally stored.
 - Eg: A fingerprint is automated through a numeric encryption of its ridges, splits, dots, valleys, and minutiae points. This encryption is called an algorithm, creating a binary encoded template.

Examples of Physical Biometrics



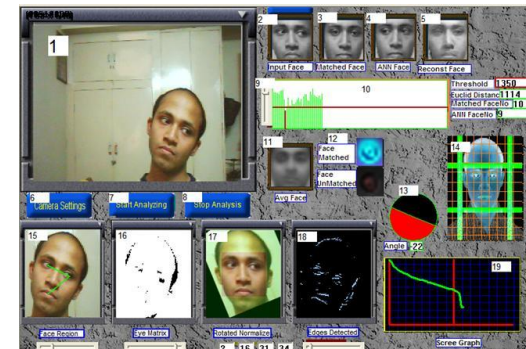
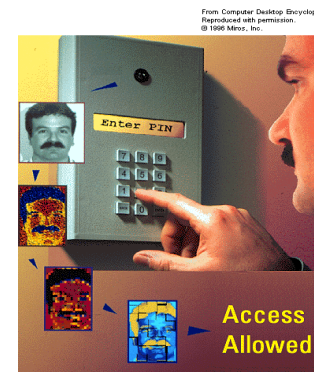
Fingerprint Recognition



Handwriting Recognition



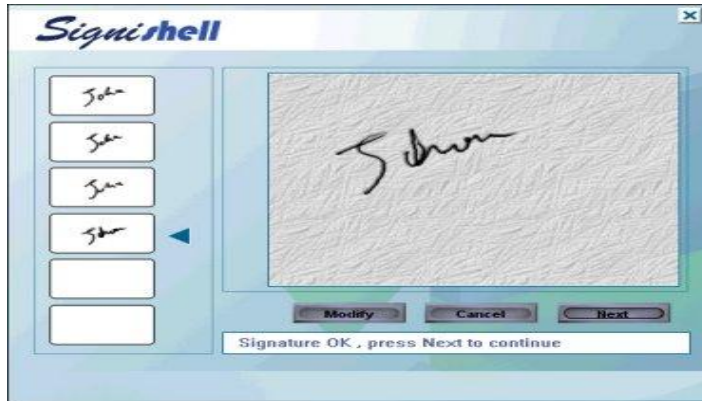
Iris Recognition



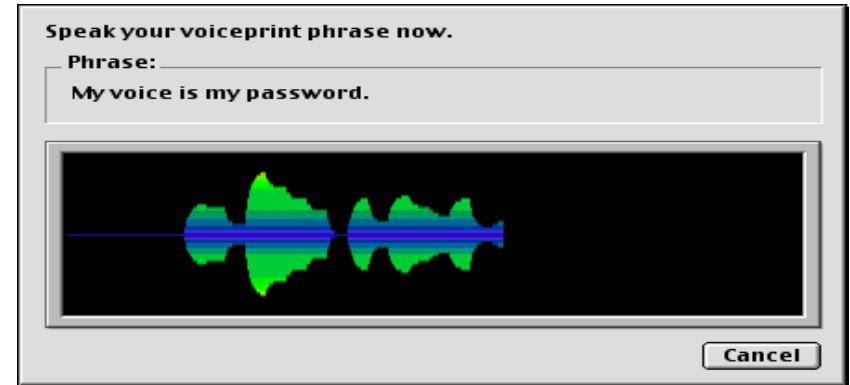
Face Recognition

- **Behavioral Biometrics:** Uses a behaviour trait or pattern, such as a voice, signature or key stroke.
- These traits are stored in a similar way to the physiological traits except **they are updated regularly to cope with the ever changing patterns in the trait.**

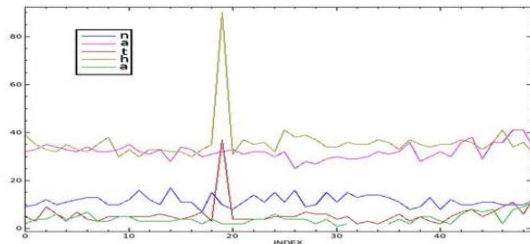
Examples of Behavioral Biometrics



Signature Dynamics



Voice Verification



Keystroke Dynamics

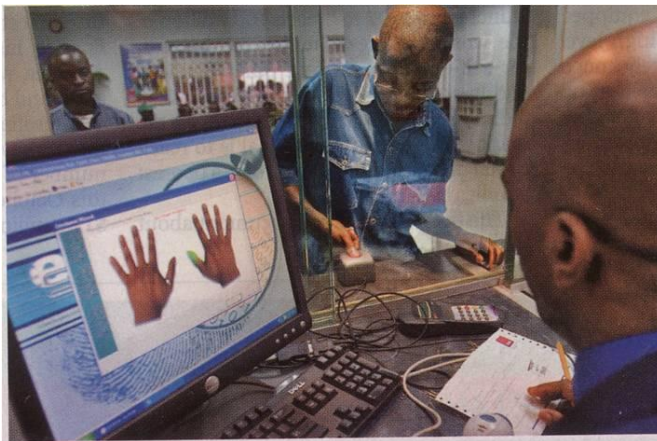
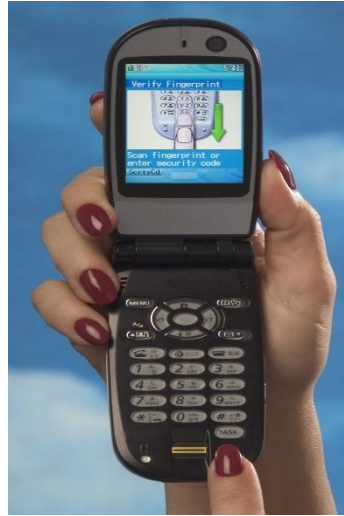


Applications of Biometrics



- Automatic Fingerprint Identification Systems (AFIS) are widely used for:
 - Forensics for criminal identification
 - Physical Access Control
 - Computer Log-in
 - Welfare Disbursement
 - National ID Cards
- In automobiles, the emerging application of biometrics is to replace keys for keyless entry and keyless ignition

Applications of Biometrics



- **False positives**
 - Allow an unauthorized user
- **False negatives**
 - Deny access to authorized users
- **For biometric authentication to work, both false positives and negatives must be low**
 - This is very difficult for computer automated verification

Fingerprints – Security Factors



- **Vulnerability to attacks**
 - Vulnerable to cloning attacks (other attacks also exist)
- **Multiple factors of authentication**
 - Can (and should) be used in combination with a password
- **Protection from phishing attacks**
 - NA
- **Effect of use on untrusted local machine**
 - NA
- **Usability as a security issue**
 - Requires a device (downside)
 - Can remember a short PIN rather than a long password

Fingerprints – Other Factors



- **Ease and cost of deployment**
 - Requires devices (cost plus physical deployment)
 - Requires a server to manage server-side authentication
- **Ease of management, including recovery**
 - Users need to remember only a single password, so less password resets
 - Loss of device needs to be taken care of
- **Applicability**
 - In principle, can be used widely, but difficult to do so
- **Usability**
 - Very good, as long as false negatives are low
- Summary: **Medium Security**

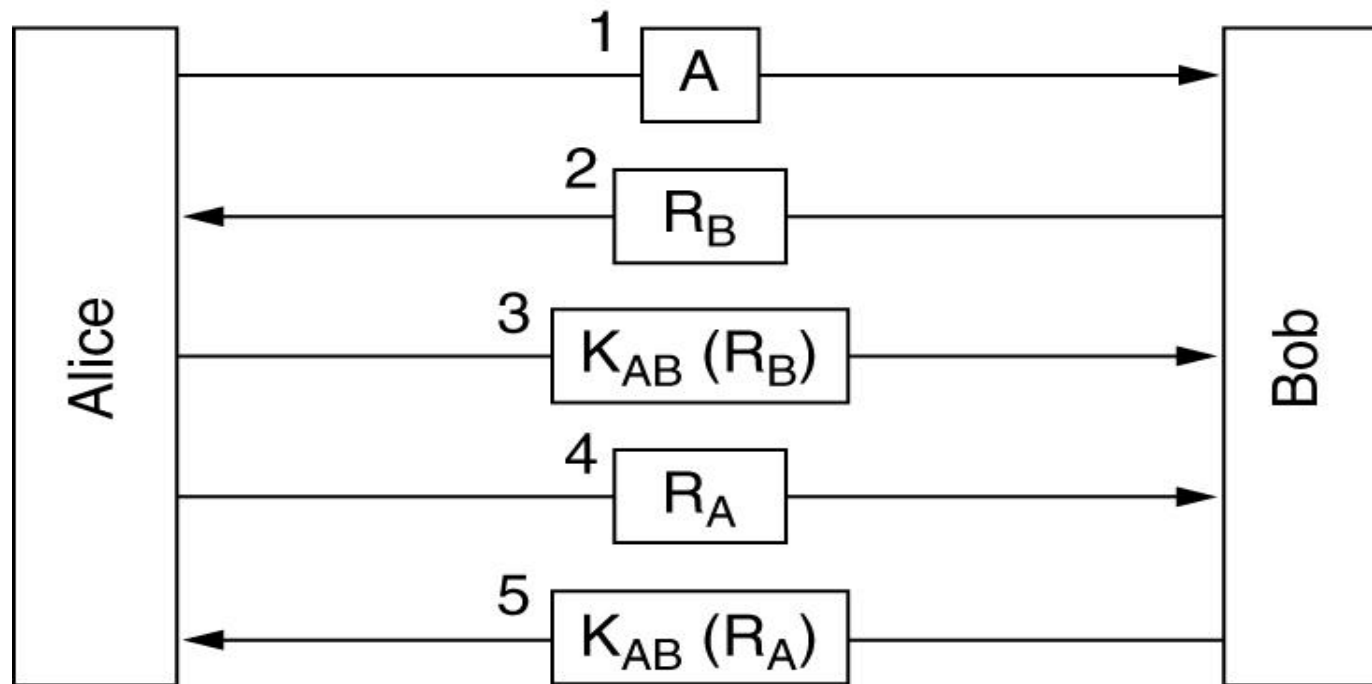
Authentication Protocols

Authentication Protocols



- Authentication Based on a Shared Secret Key
- Establishing a Shared Key: Diffie-Hellman
- Authentication Using a Key Distribution Center
- Authentication Using Kerberos
- Authentication Using Public-Key Cryptography

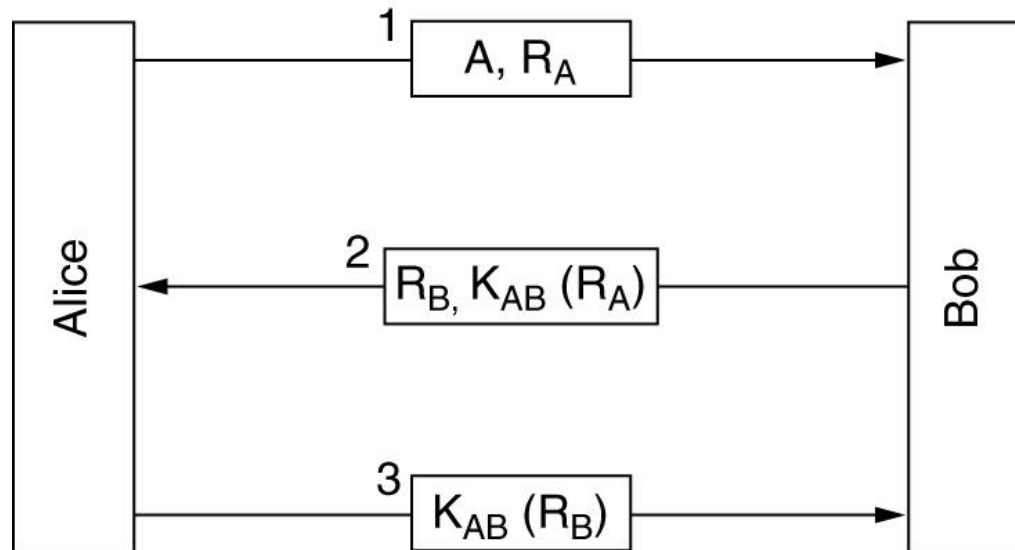
Authentication Based on a Shared Secret Key



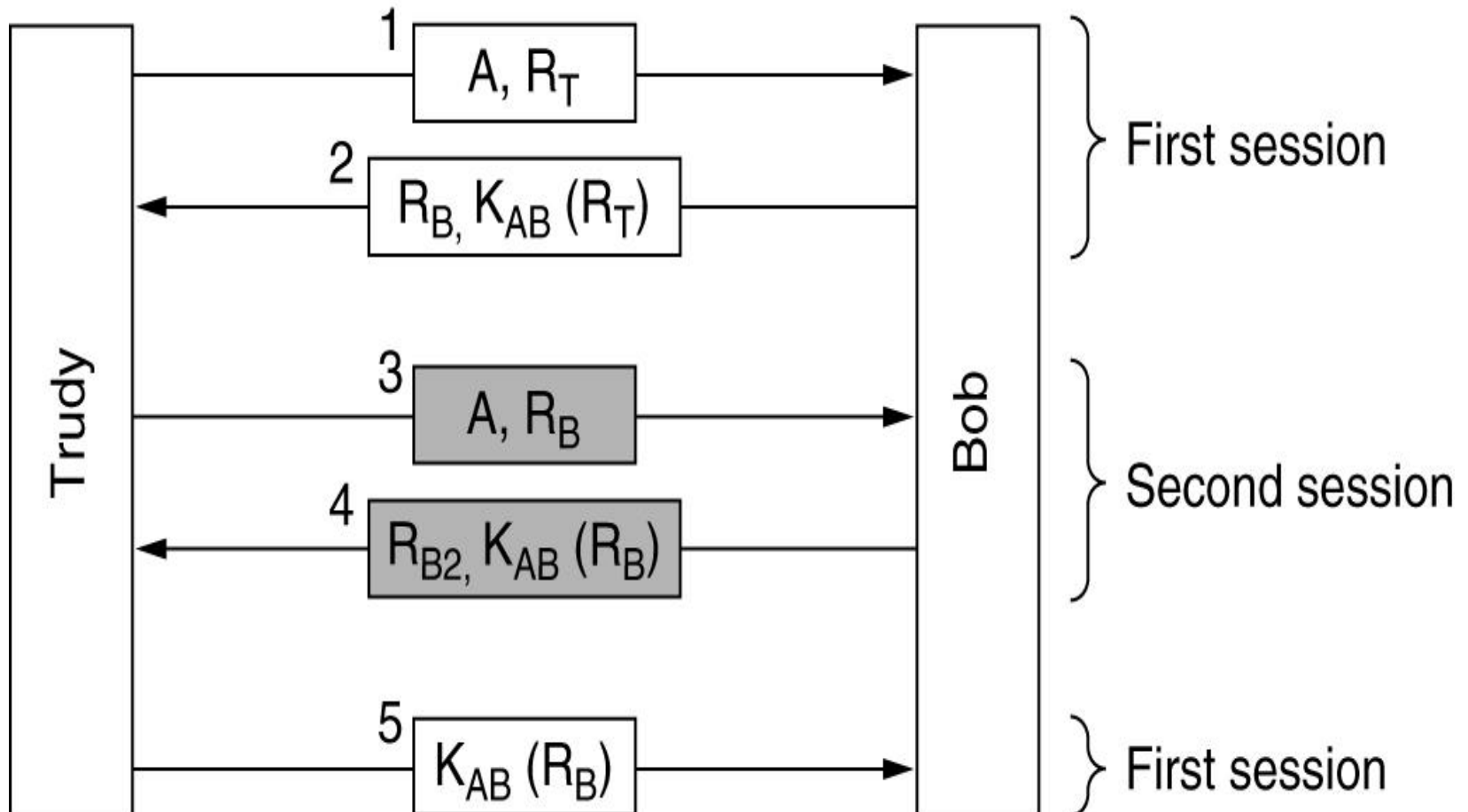
- Two-way authentication using a challenge-response protocol.

Authentication Based on a Shared Secret Key (2)

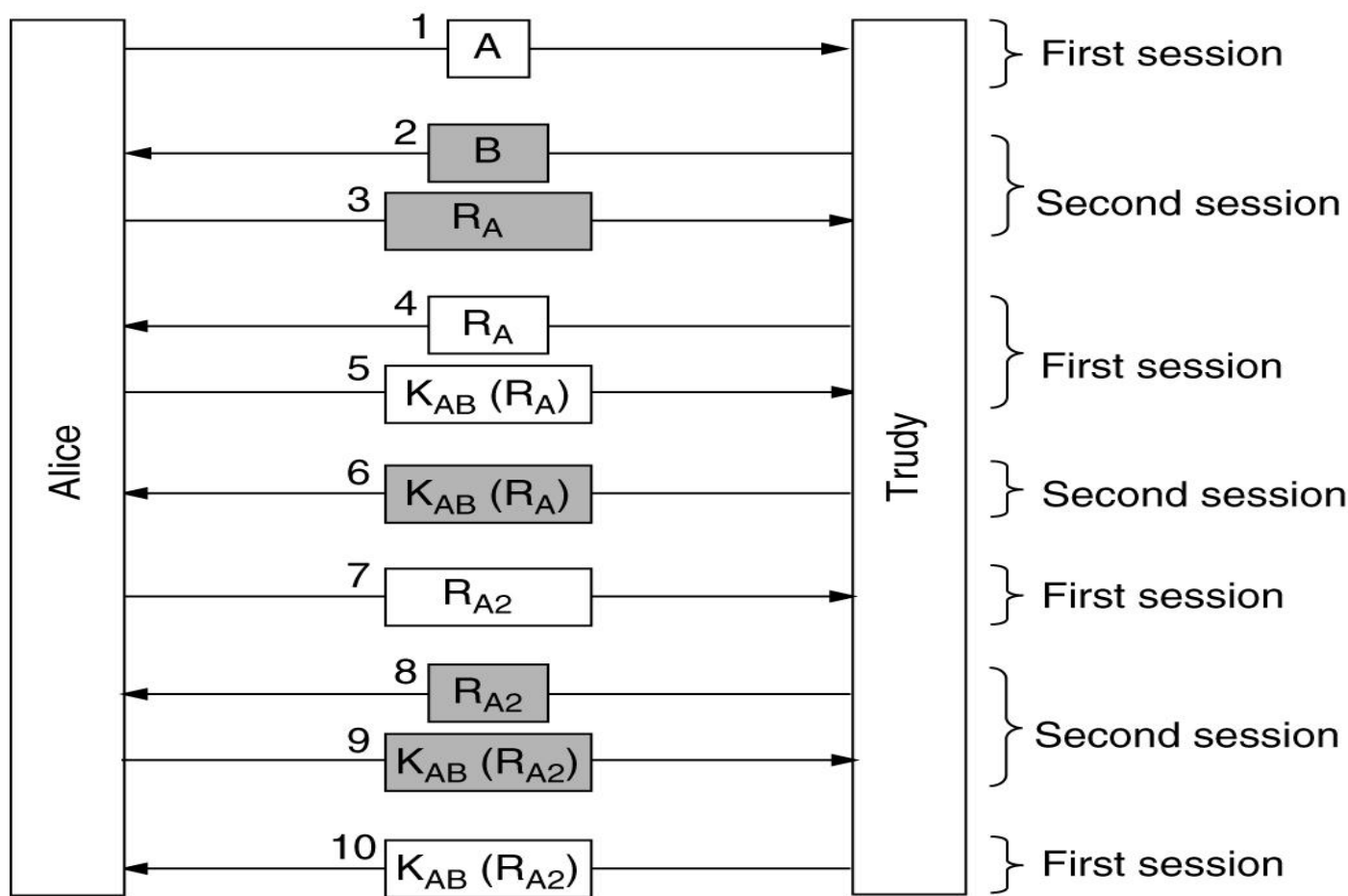
- A shortened two-way authentication protocol.



The Reflection attack

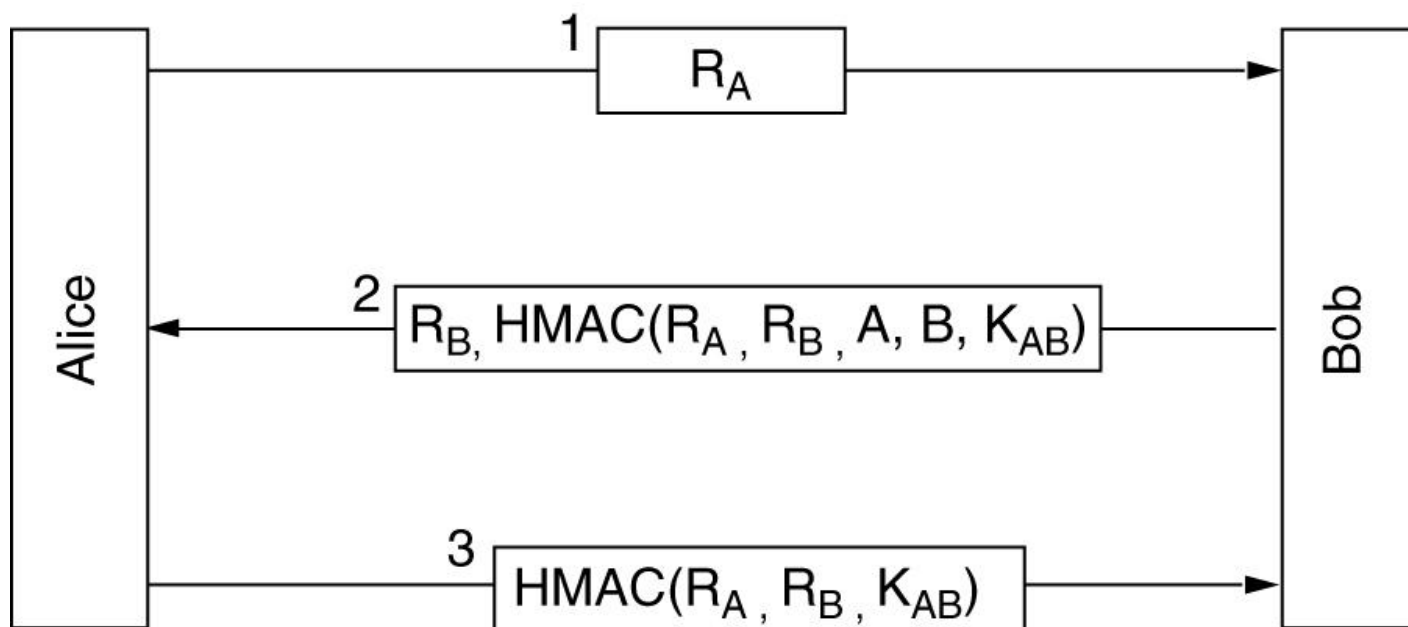


Authentication Based on a Shared Secret Key (4)



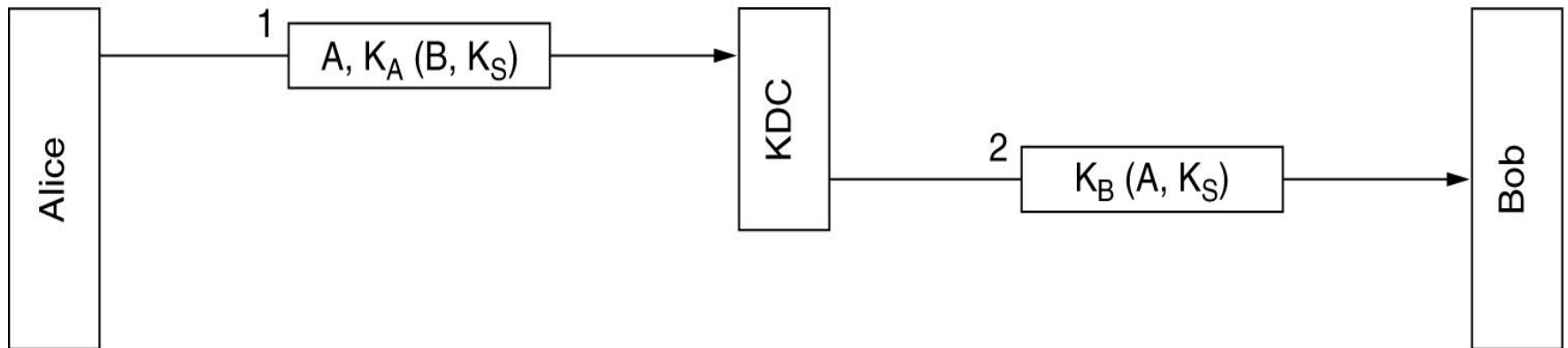
Authentication Based on a Shared Secret Key (5)

- Authentication using HMACs.

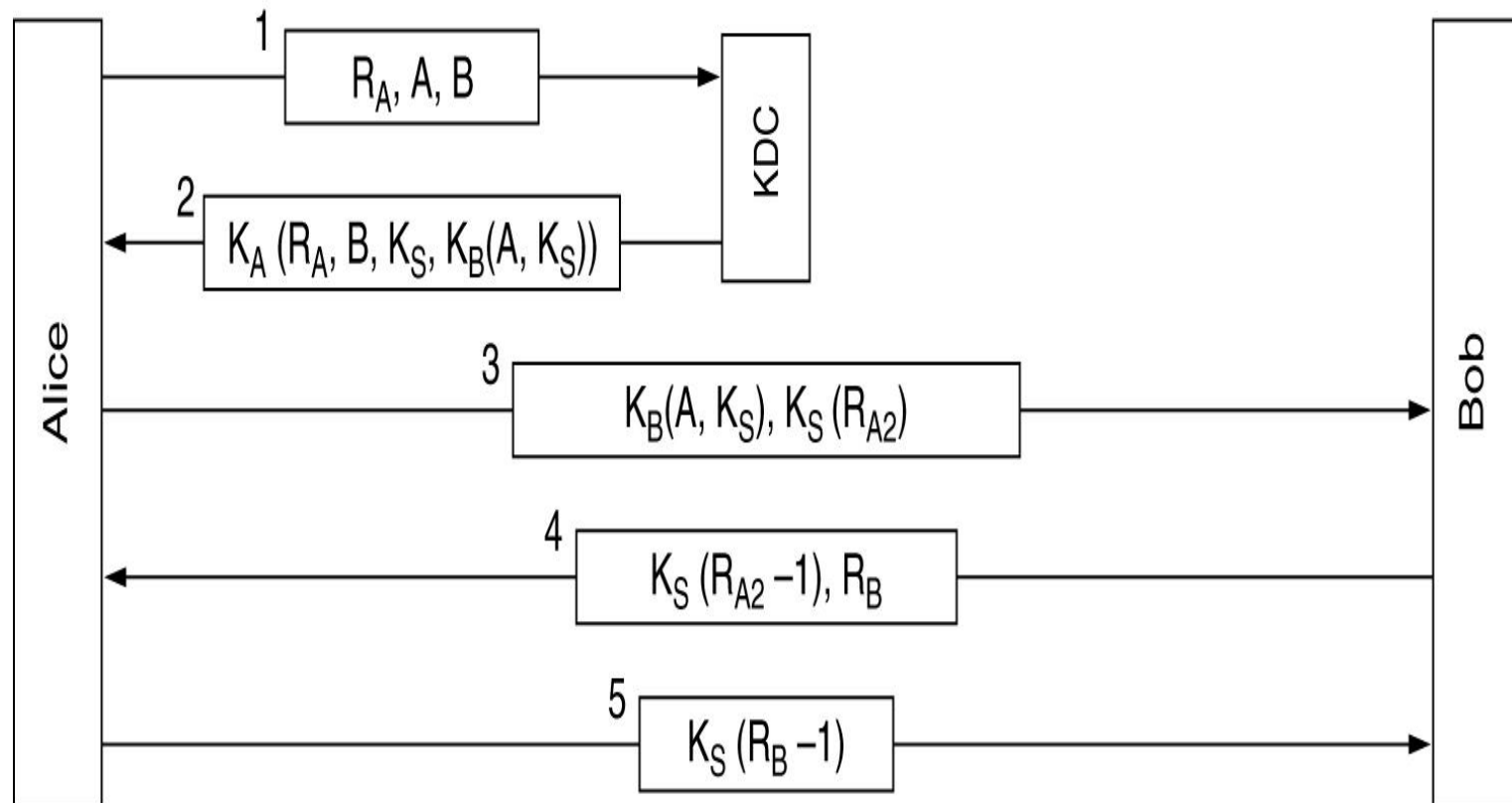


Authentication Using a KDC

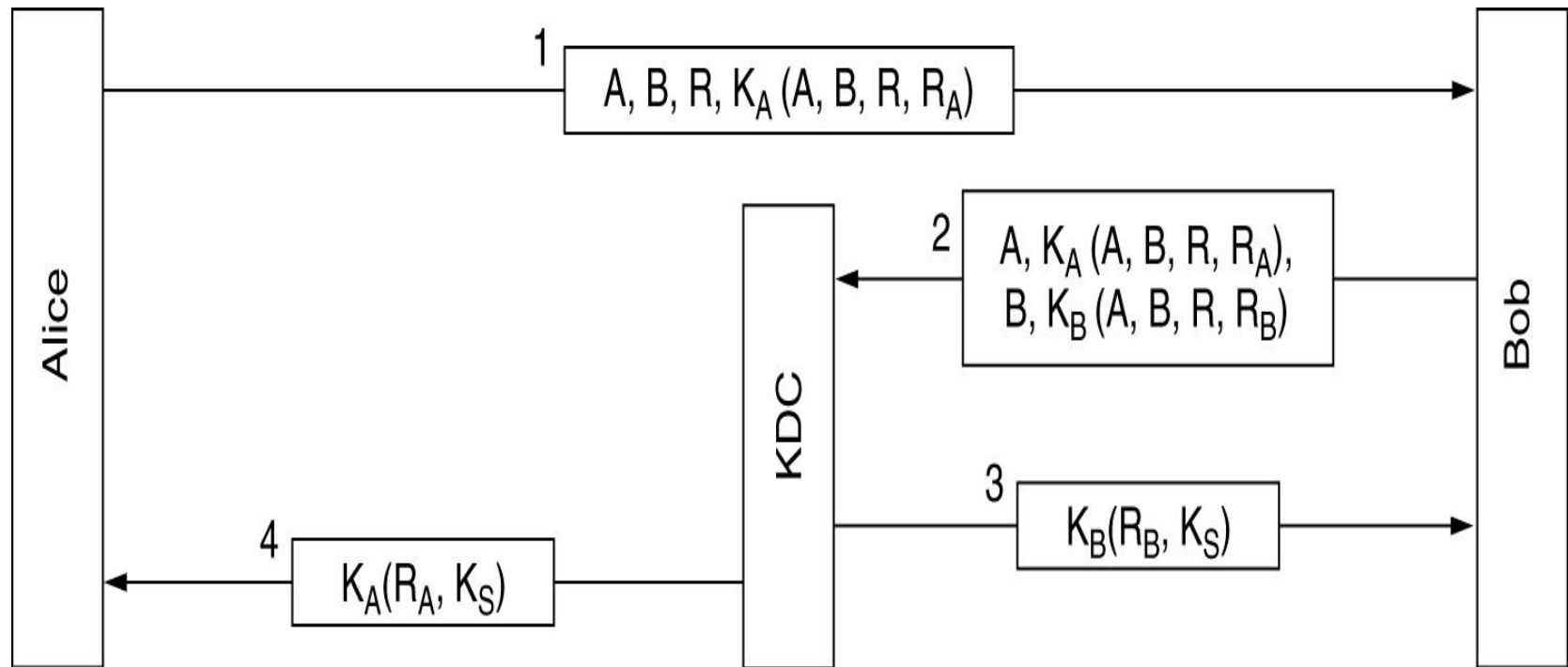
- A first attempt at an authentication protocol using a KDC.



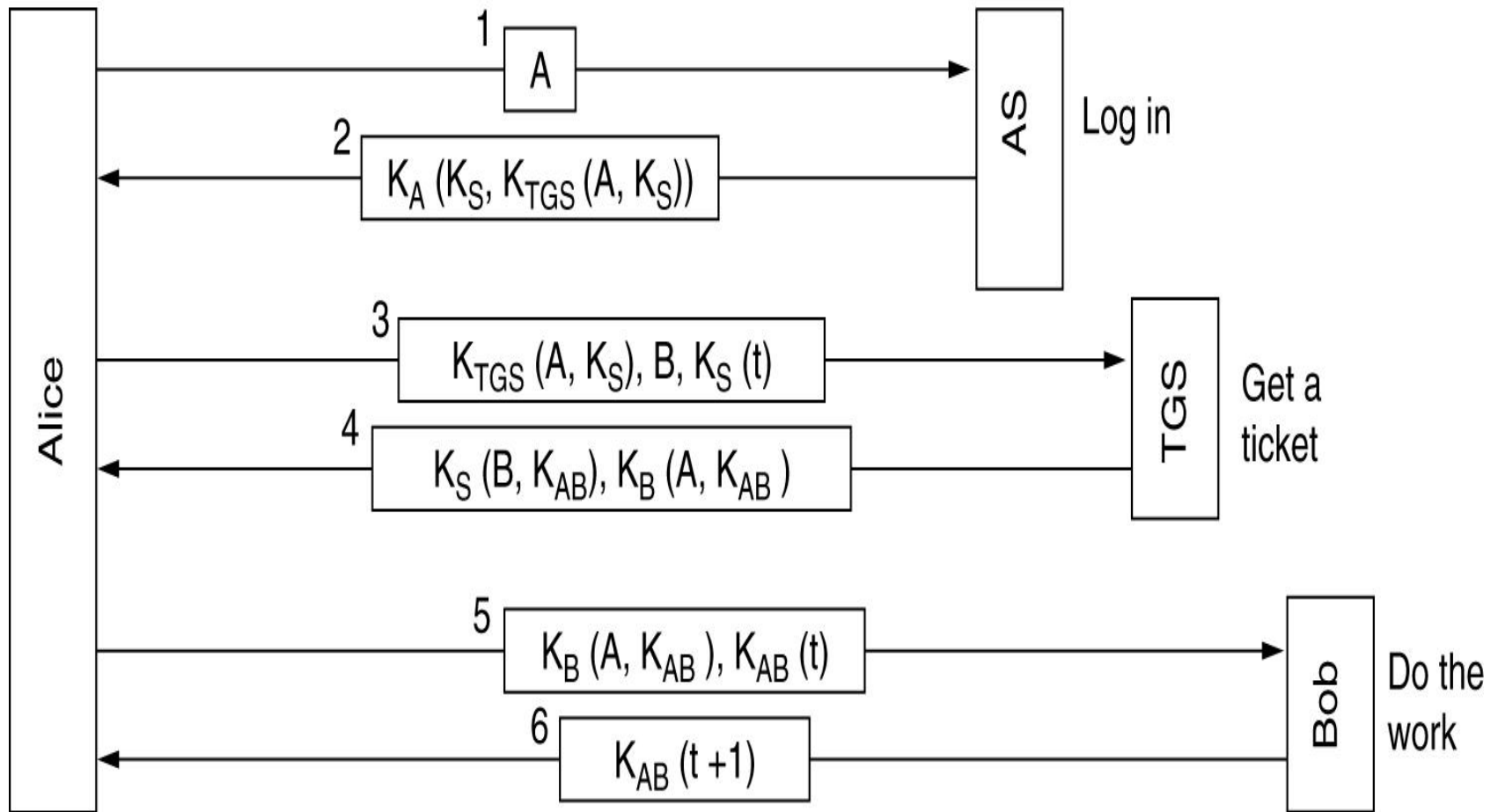
The Needham-Schroeder protocol



The Otway-Rees authentication protocol

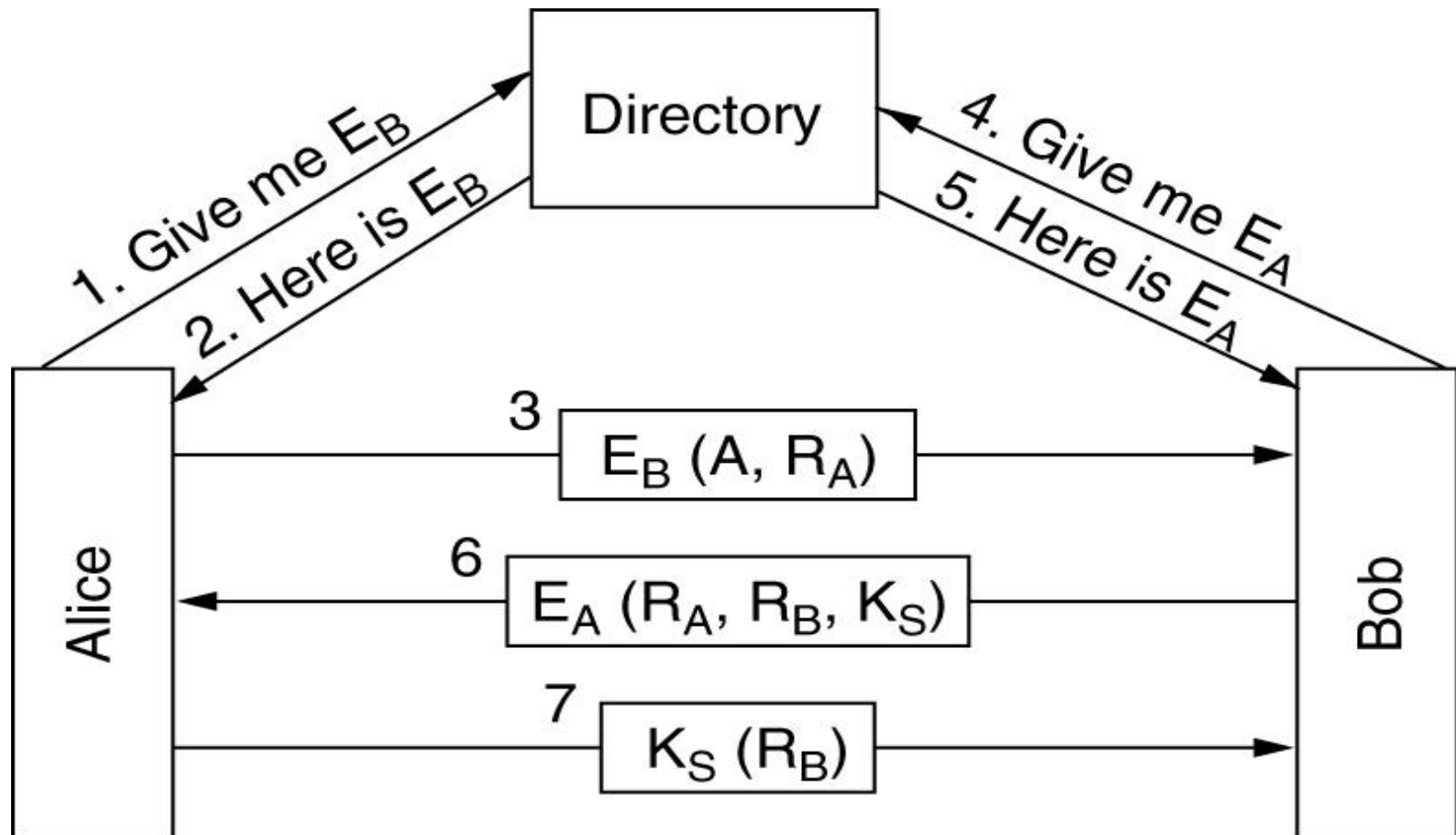


Authentication Using Kerberos



Authentication Using PKC

- Mutual authentication using public-key cryptography.



Key Challenge – 4:

Authentication without Password Table

Authentication without Password table



- It uses two-factor based authentication Using Smart Cards
- First Protocol using smart card was proposed by Lamport in 1981 but this required password table
- Various other protocols were proposed based on ECC, PKC etc. without requiring password table
- In 2000, Sun et al. proposed smart card based authentication using cryptographic hash functions but all these were based on static ID's leading to ID theft
- In 2004, Das et al proposed Dynamic ID based authentication protocol using smart cards
- Various enhancements and variations to Das et. Al's scheme have been proposed

Research Objectives



- To Provide
 - Two factor based authentication
 - Authentication without Password / Verification table
 - Secure Mutual Authentication & Key Agreement
 - Secure and Usable Authentication
 - Five Password variants including Textual, Graphical and Text-o-Graphic Passwords
 - Flexibility of switching from one password method to another
 - Secure against attacks such as Stolen Verifier attack, Dictionary attacks, Shoulder surfing attack, Guess attack.
 - Cost effective solution
 - Access from any location

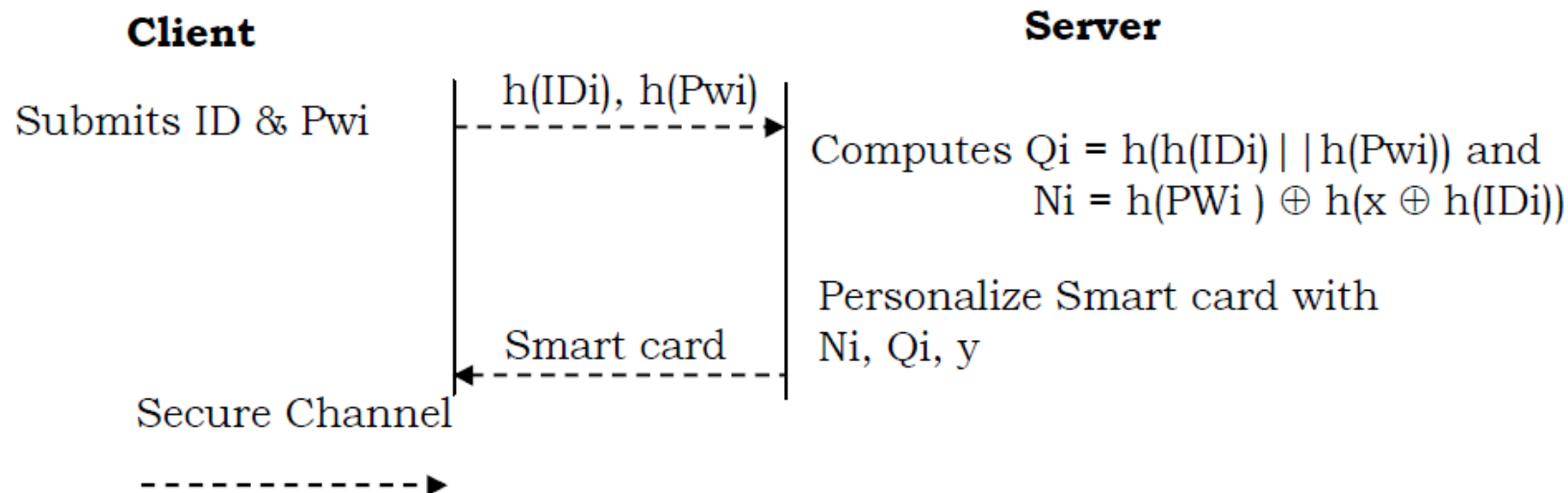
A Textual Password based Authentication Scheme

A Text Password based Authentication Scheme

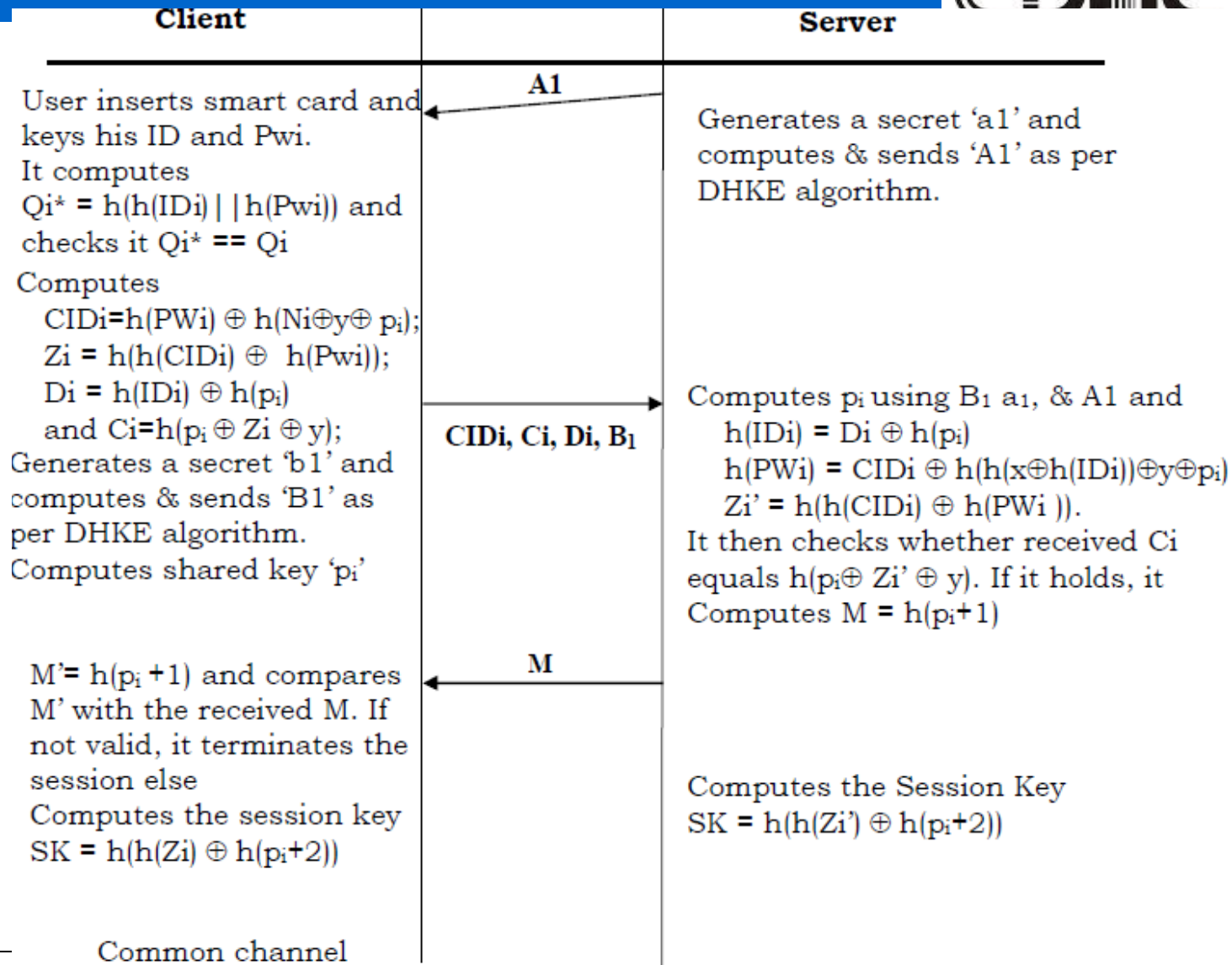


- A Two-factor Authentication Scheme
- Second factor is Smart Card / Soft Token / USB
- Provides Secure Authentication and Key Agreement
- Provides efficient computation as Hash functions are used
- Authentication without verifier table
- Secure against Replay, Stolen-Verifier, Reflection attacks etc.
- Scheme has three phases namely 1) Registration 2) Mutual Authentication and Key Agreement 3) Password Change Phase
- Suitable for e-commerce solutions

Registration Phase



Mutual Authentication & Key Agree



Password Change Phase

Client

User Submits Password change request by generating random no. P_k . Encrypts it with Sk ,

Decrypts as $E_{Sk}(Page, P_{k+1})$ and verifies the freshness of nonce. Client displays password change page.

User submits old and new password. Client computes $N_i^* = h(PW_i)^* \oplus h(PW_i) \oplus N_i$; Replaces N_i with N_i^* .
Updates Smart card with $\{N_i^*, Q_i, y\}$

Server

Decrypts it and Checks the freshness of P_k , Picks a random Image Set; Sends password change phase along with P_{k+1} encrypted with Sk

$E_{Sk}(P_k)$

$E_{Sk}(Page, P_{k+1})$

Sends conf. Msg

Session key encrypted channel

Key Challenge – 3 :

Providing Usability with Improved
Password Strength using Graphical
Passwords

- Use graphics rather than alphanumeric characters
- “Imprinted memories”
 - Easily *recognize* something, but
 - Difficult to *recall* systematically

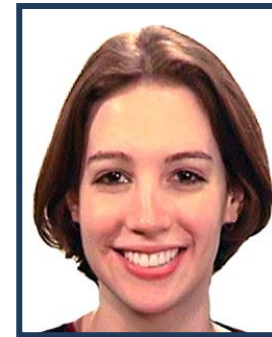
Recall vs. Recognize



You must **RECALL** a password



You simply **RECOGNIZE** a face



Remember High School
Fill in the Blank

1 2 3 g f w y

What kind of test did you prefer?
Multiple Choice



Definition



- A graphical password is a secret that a human user inputs to a computer with the aid of the computers' graphical input devices e.g., mouse, stylus, or touch screen.

- Graphical password is a good solution to the password problem.
- The idea of graphical password was pioneered by Greg Blonder who also holds the US patent 5559961 (1996).
- His idea – is to let the user click (with a mouse or stylus) on a few chosen (pre-designed) regions in (pre-processed) an image that appears on the screen.

- Images are easy to remember
 - Especially if you invent a memorable story to go along with the images
- Dictionary attacks on graphical passwords are believed to be difficult
 - Images are very “random”
- Still not a perfect solution
 - Need infrastructure for displaying and storing images
 - Shoulder surfing

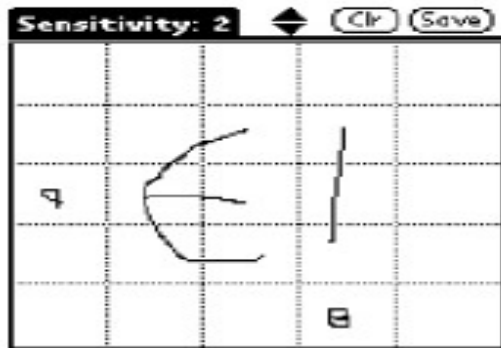
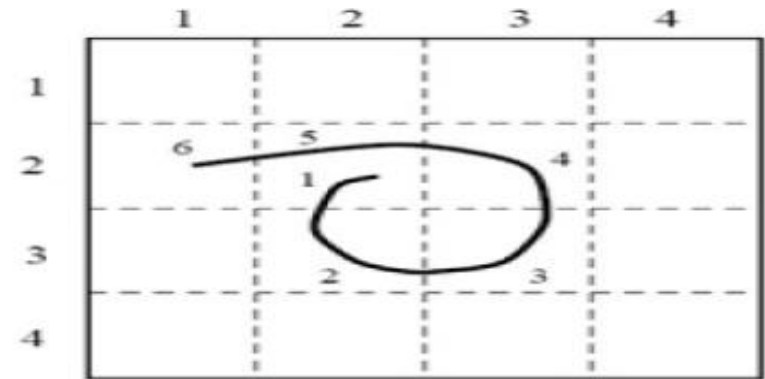
- Some early work:
- Pure Recall Based Graphical Password systems
 - Draw-a-Secret
- Cued Recall Based Graphical Password systems
 - Passlogix
 - PassPoint
- Recognition Based Graphical Password systems
 - déjà vu²
 - Passfaces

Graphical Passwords

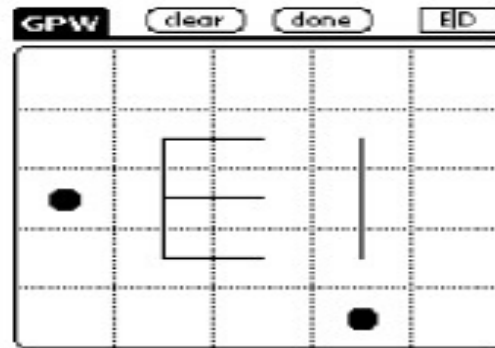


- Some early work:
- **Drawmetric** - Pure Recall Based Methods
- **Locimetric** - Cued Recall Based Methods
- **Cognometric** - Recognition Based Methods

Draw-A-Secret – Jermyn et al.



(a) User inputs desired secret



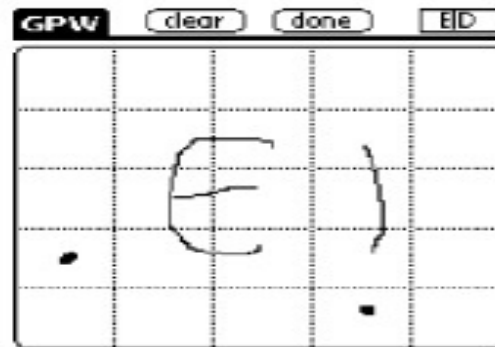
(b) Internal representation



(c) Raw bit string



(d) Interface to database

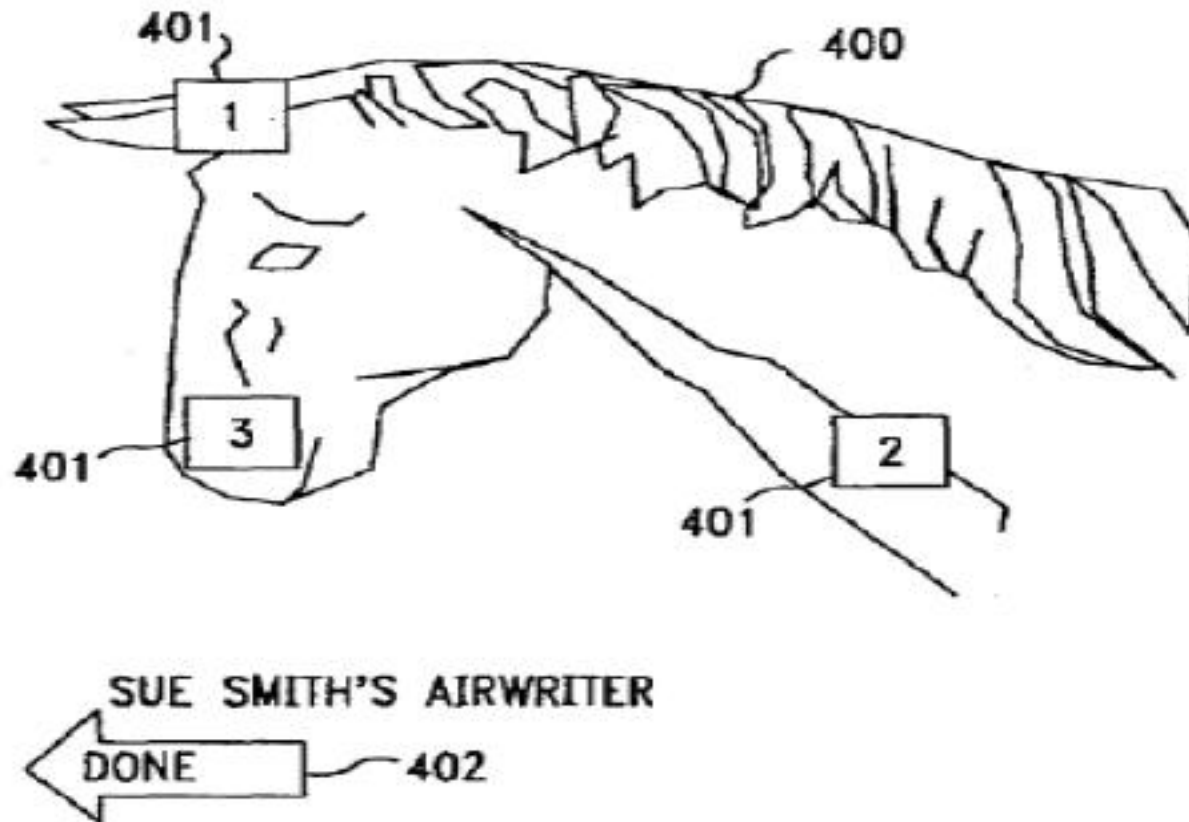


(e) Re-entry of (incorrect) secret

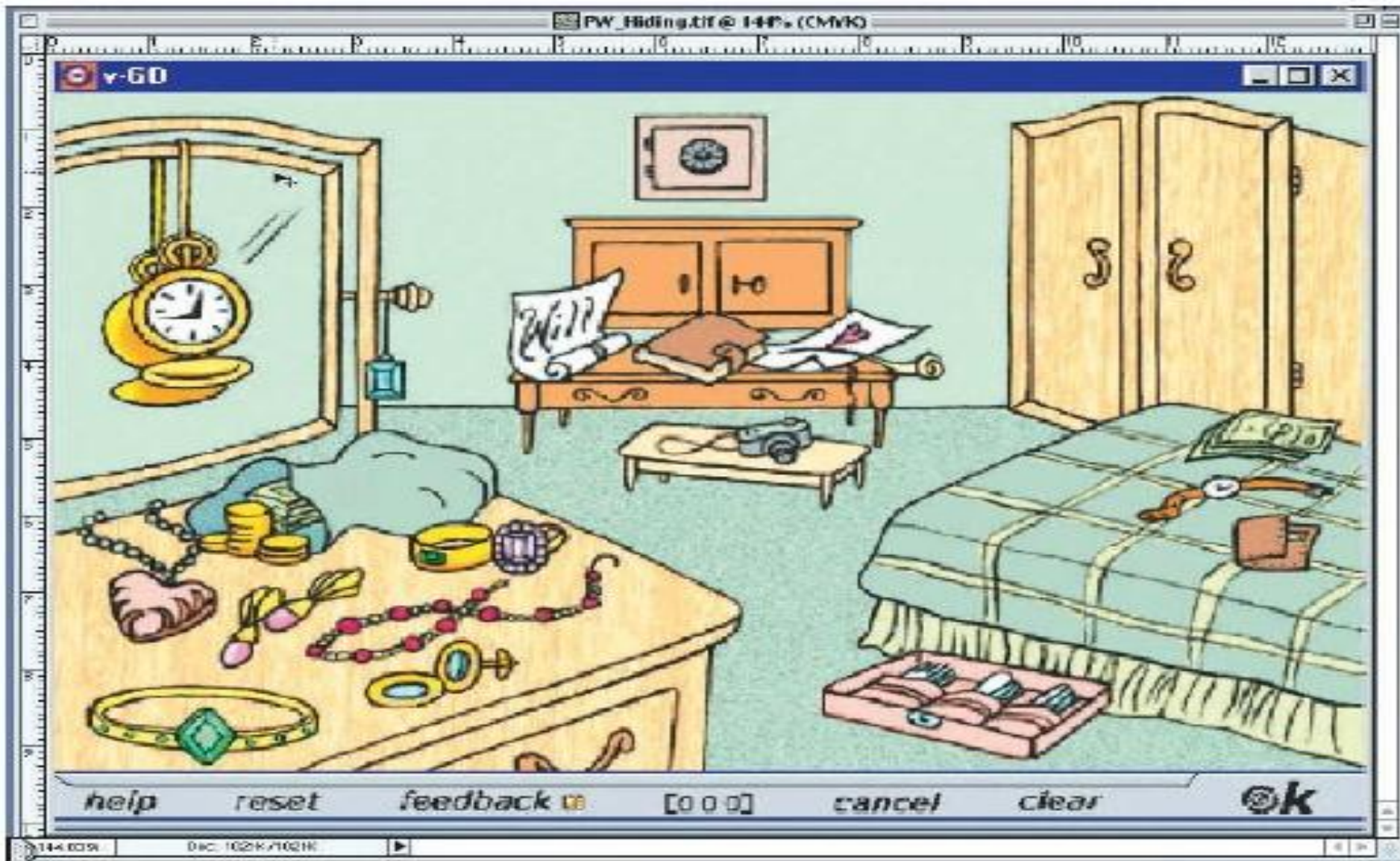


(f) Authorization failed

Blonder's Graphical Password



PassLogix – Weidenbeck et al.

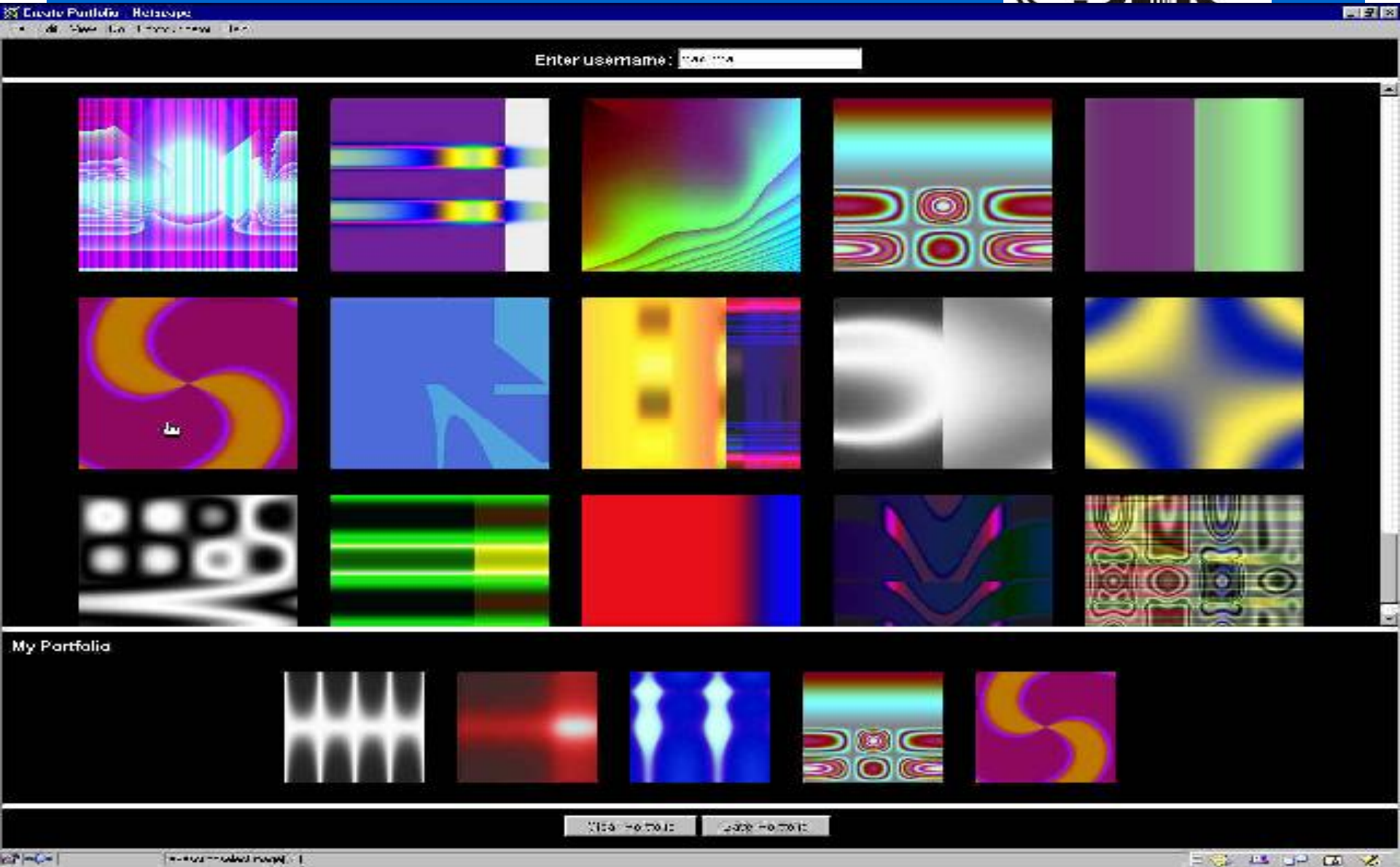


PassPoint

सी डैक
CDAC

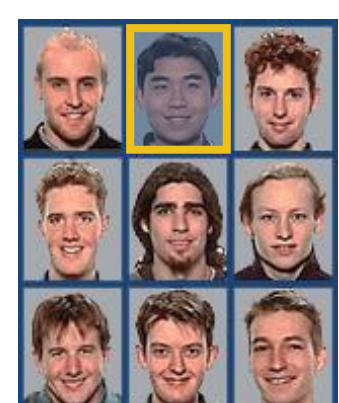


déjà vu – Dhamija R



Multi-factor Authentication employing Graphical Passwords

Passfaces — Real User Corporation



Click On
Your Passface

It's Moving

(There is only One
on this Page)

Vidoop

सी डैक
CDAC

Browser window showing the myvidoop.com login page. The address bar displays <https://myvidoop.com/login>. The page features a 4x4 grid of images for CAPTCHA verification, each with a red circle containing a letter. The letters, read row by row, are: U, W, Y, K, Q, A, M, B, P, G, E, O. Below the grid is an "Access Code:" input field and a "Secure Login" button. Links for "Can't Login?" and "Account Recovery" are provided. The page is secured by vidoop, as indicated by the logo and text "secured by vidoop".

Copyright © 2008 Vidoop LLC. US and International Patents [Issued](#) and Pending. [Image Credits](#).

Create a [myVidoop account](#) and start using it to sign in to all your favorite websites using a **single username**.

You control your own experience and security. And with myVidoop browser integration features, your online identity becomes easily manageable from **anywhere, anytime**.

05/30/2008
Updated: Check out the latest release notes for myVidoop.com on [the Vidoop Blog](#) »

01/16/2008
OpenID 2.0: myVidoop has adopted the OpenID 2.0

myVidoop Registration



myvidoop

Registration

Category selection

Select 3 secret categories

1. Choose 3 secret categories that you can remember.
2. Click "I'm done choosing my secret categories".

Note: The order in which you choose your categories is not important and you may choose up to 3 required categories.

I'm done choosing my secret categories

3 Selected | [Clear Selection](#)



Flowers



Wild Animals



Skyscrapers



Cats



Stained Glass



Underwater



Dogs



Boats



Musical Instruments



Locks And Keys



Cars



Clocks



Outer Space



Insects



Money



Castles



Trains



Beverages



Food



Complains



Houses



Telephones



Aircrafts



Birds



People



Toys And Games

Type in the letters next to your secret categories:

myVidloop Authentication



Type in the letters next to your secret categories:

[Secure Login](#)

[I forgot my categories](#)

Copyright © 2008 Vidloop LLC. US and International Patents Issued and Pending. Image Credits.

Activating the Browser



Is this your computer?

You are not logging in from one of your saved computers.
You need an activation code to log in. ?

Please choose how you want to receive your code:

My Registration email ▼

Send activation code

[I have already received my activation code.](#)

We have sent an activation code to the email address you selected. If you don't receive it immediately, please wait a few minutes. Delivery may have been delayed.

[x Send Another Code](#)

Activation Code (6-digit #): 088664

Continue

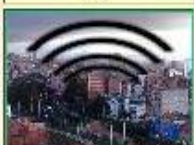
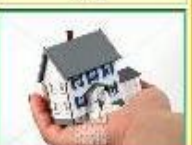
☒ This is my computer ?

Give this browser a name: ?

Mozilla (optional)

Text-o-Graphic Password

S-16 (Text-o-Graphic Password)

			
1	2	3	4
			
5	6	7	8
			
9	10	11	12
			
13	14	15	16

Enter Text Password : Enter Image No. :

Submit

$$PW_i = h\{ [h(t1) \parallel h(I1)] \}$$

STARS Password Variants

Textual Password

Block

...

Submit

S-27 (Graphical Password)

GRID 1			GRID 2			GRID 3		
								
1	2	3	1	2	3	1	2	3
								
4	5	6	4	5	6	4	5	6
								
7	8	9	7	8	9	7	8	9

GRID 1 Image No. : ●

GRID 2 Image No. : ●

GRID 3 Image No. : ●

Submit

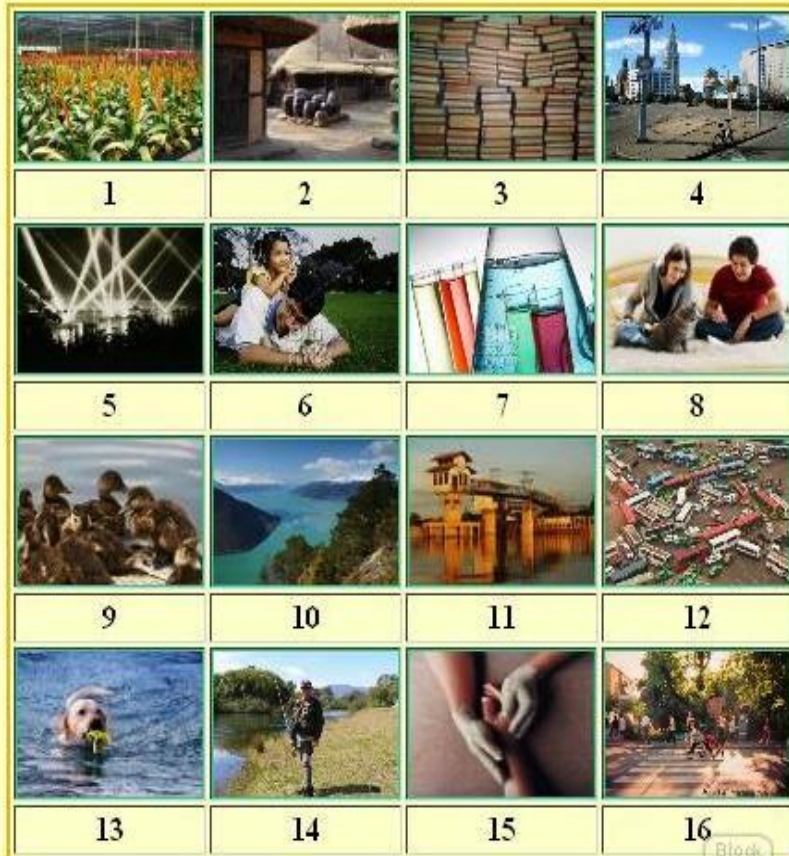
S-27 (Text-o-Graphic Password)

GRID 1			GRID 2			GRID 3		
								
1	2	3	1	2	3	1	2	3
								
4	5	6	4	5	6	4	5	6
								
7	8	9	7	8	9	7	8	9

GRID 1 Password :		GRID 1 Image No. :	
GRID 2 Password :		GRID 2 Image No. :	
GRID 3 Password :		GRID 3 Image No. :	

S-16

S-16 (Graphical Password)



Enter 3 Image No. seperated by "," :

.....

Submit

S-16 (Text-o-Graphic Password)



Enter Text Password :

.....

Enter Image No. :

.....

Submit

e-Pramaan: A National e-Authentication Framework – An Introduction

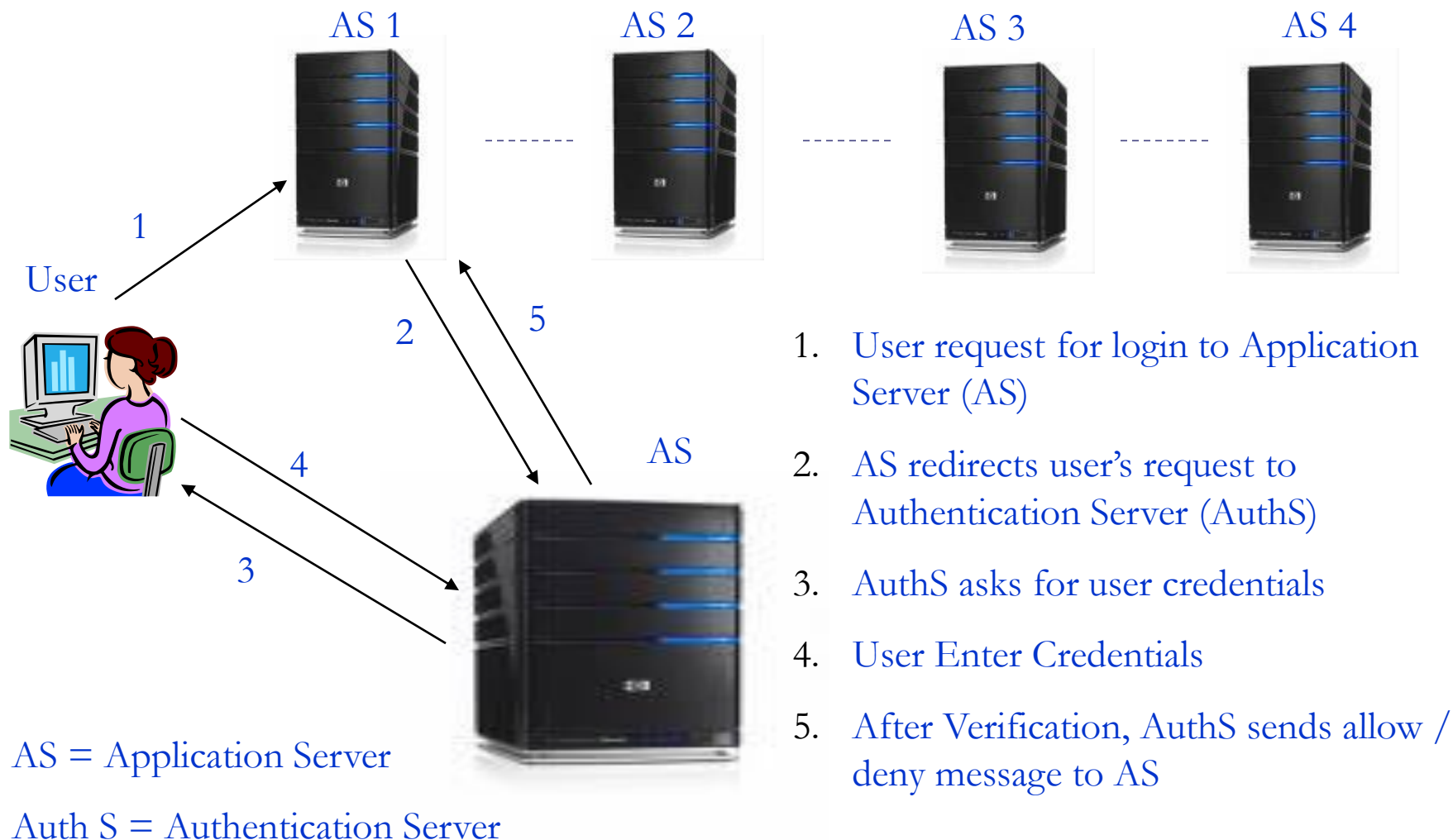


e-Pramaan – An e-Authentication Solution for Citizens

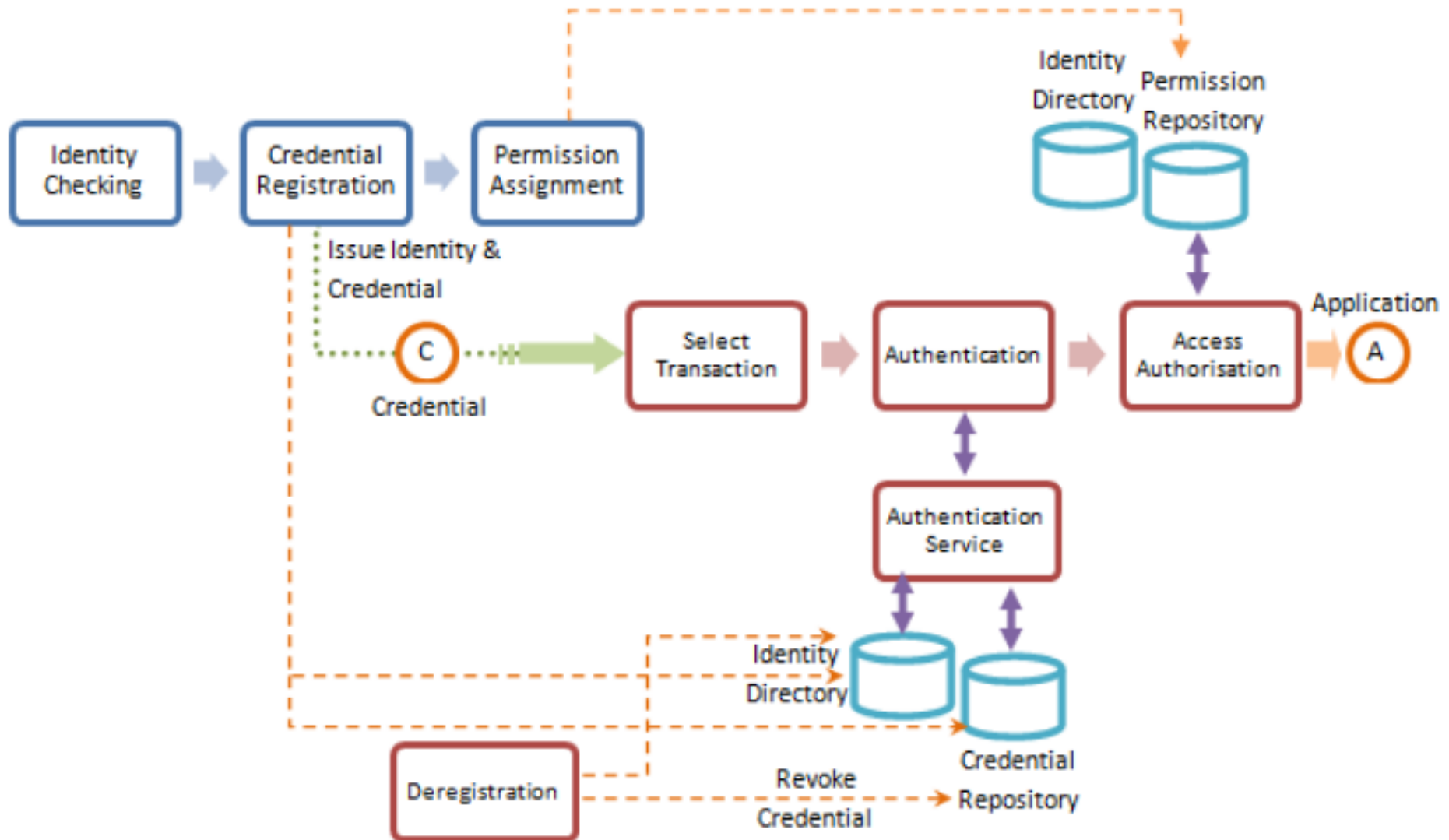


- e-Pramaan – An Electronic Authentication Framework for the Govt. Agencies to Authenticate and Authorize the citizens to a desired level of assurance and confidence.
- e-Pramaan has 4 levels of Authentication. The application sensitivity defines the level of the authentication mechanism

Authentication As a Service (AAS)



Technology Architecture (IAM)



IAM Components



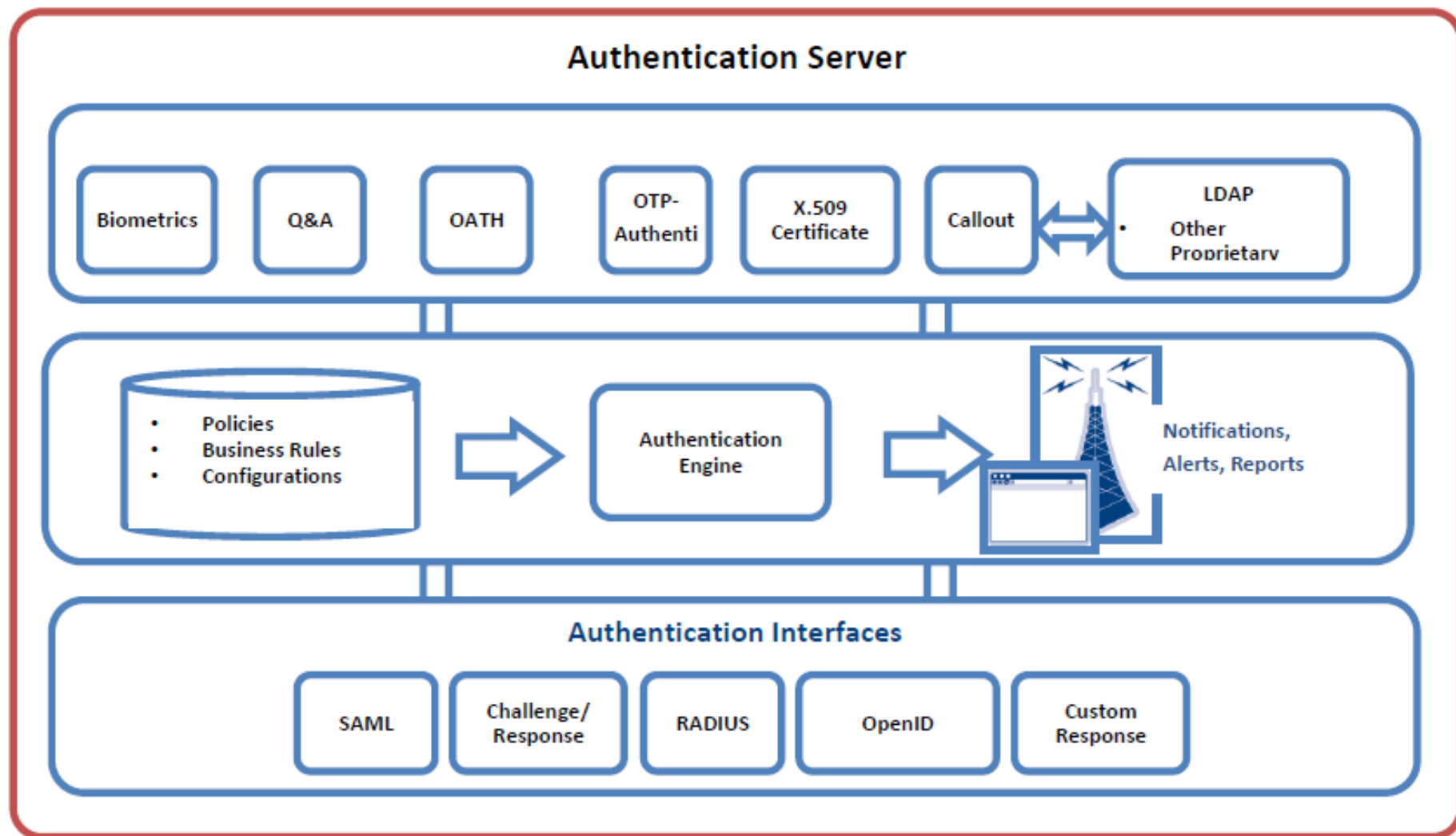
- The e-Pramaan framework classifies the IAM components into four major categories
 - (i) **Authentication**
 - Single Sign-On
 - Step-up authentication/Strong authentication
 - X.509 certificate
 - Hardware/Software Token
 - OTP
 - Biometric Authentication
 - (ii) **Authorisation**
 - Role/Rule based
 - Attribute based
 - Remote Authorisation

IAM Components



- (iii) Identity Management
 - User management (includes creation/deletion/modification in the end application as per the role defined in Identity Management)
 - User self-service
 - User request for additional application access
- (iv) Central User Repository & User Activity Reporting
 - Directory
 - User Activity Reporting

High Level Architecture



Levels of Authentication



	Application Sensitivity				
Sensitivity Level	Level 0	Level 1	Level 2	Level 3	Level 4
User Experience	No inconvenience	Minimal inconvenience	Minor inconvenience	Significant inconvenience	Substantial inconvenience
Scenarios	Public information	Information with minimal impact in case of theft	Information having social impact but no financial/security impact	Information having financial/security impact	Information having very high financial/security Impact
Suggested Authentication Method	No Authentication required	Username-Password	Digital certificate/soft token	Two factor authentication: Soft/hardware token along with Username and Password	Two factor authentication: Biometric + Token / Username and Password

References



- Cryptography and Network security – principles and practice
William Stallings
- Applied Cryptography, Second Edition: Bruce Schneier
- http://campustechnology.com/articles/39190_2
- <http://csrc.nist.gov/>
- Handbook of Applied Cryptography, by Menezes
- <http://en.wikipedia.org>
- Cryptographic Techniques for N/w Security

References



- <http://openidexplained.com/>
- A Large-Scale Study of Web Password Habits:
by Dinei Flor ^ encio and Cormac Herley of
Microsoft Research - Proc. WWW2007
- <http://openid.net>
- Computer Desktop encyclopedia: Computer
Language Co. Inc.
- www.myvidoop.com

References



- Draft National e-Authentication Framework, Ver 1.0, 01-09-2011 – DIT, MCIT
- Aadhaar Authentication Framework, Ver 2.0, UIDAI

Thank you

Queries ?

misbah@cdac.in